

Anot Health

Complete Platform Documentation

Architecture · Operations · Security & Compliance

Generated: June 16, 2026 at 9:01 AM
Confidential — for internal IT and operations use only.

Table of Contents

1. Platform Documentation	3
2. Admin Onboarding	26
3. Clinician Onboarding	31
4. Disaster Recovery	36
5. Cost Monitoring	41
6. Security & Compliance Manual	45
7. Breach Response Plan	53
8. Risk Assessment	59
9. Privacy Policy	64
10. Terms of Service	68
11. HIPAA Compliance Sign-Off	72

Platform Documentation

Anot Health — Platform Documentation

Version 1.0 · June 16, 2026

A comprehensive technical and operational guide to the Anot Health platform: a HIPAA-aware clinical documentation system that turns recorded patient encounters into reviewed, approved clinical notes.

Audience: engineers, operators ([super_admin](#)), and onboarding staff. This document is the single source of truth for architecture, deployment, data model, and operations. For task-specific procedures see the companion docs referenced throughout ([docs/COST_MONITORING.md](#), [docs/DISASTER_RECOVERY.md](#), [SECURITY_AND_COMPLIANCE_MANUAL.md](#), [BREACH_RESPONSE_PLAN.md](#)).

Table of Contents

1. [Platform Overview](#)
 2. [Architecture](#)
 3. [System Components](#)
 4. [Deployment Architecture](#)
 5. [User Roles & Permissions](#)
 6. [Key Workflows](#)
 7. [API Endpoints](#)
 8. [Database Schema](#)
 9. [Security & Compliance](#)
 10. [Configuration & Environment Variables](#)
 11. [Monitoring & Logging](#)
 12. [Disaster Recovery](#)
 13. [Cost Monitoring](#)
 14. [Known Limitations & Future Work](#)
 15. [Troubleshooting](#)
 16. [Useful Links & References](#)
 17. [Deployment Checklists](#)
 18. [Contact & Support](#)
-

1. Platform Overview

What is Anot Health?

Anot Health is a clinical documentation platform that converts recorded patient encounters into structured, reviewed clinical notes. It removes the manual burden of charting by recording the visit audio, transcribing it with speech-to-text, drafting a note with AI, and then routing that draft through a human review-and-approval chain before it is uploaded to the EHR. Every action that touches protected health information (PHI) is audit-logged for HIPAA compliance.

Core Workflow

```
record -> transcribe -> AI draft -> scribe review -> clinician approve -> EHR upload
```

1. **Record** — a clinician records the patient encounter (microphone audio) against a visit.
2. **Transcribe** — the audio is sent to Deepgram (speech-to-text); segments are stored on the note.
3. **AI draft** — Anthropic Claude turns the transcript into a structured clinical note draft.
4. **Review** — a scribe reviews/edits the draft and submits it as ready.
5. **Approve** — the clinician reviews and locks/approves the note.
6. **Upload** — the approved note is uploaded to the EHR (currently a manual step).
7. **Quality** — QPS staff grade submitted notes on accuracy, completeness, terminology, and formatting.

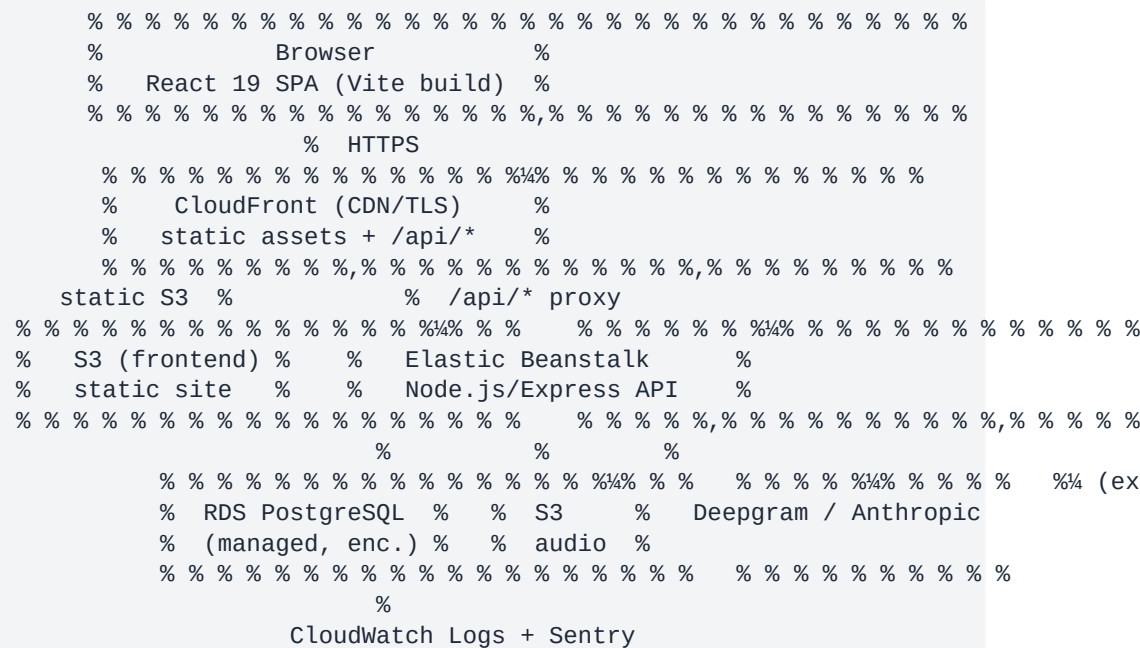
Technology Stack

Layer	Technology
Frontend	React 19, Vite 8, React Router 7, Recharts
Backend	Node.js 22, Express 5
Database	PostgreSQL (AWS RDS)
Audio storage	AWS S3
CDN / hosting	AWS CloudFront + S3 (static)
Backend host	AWS Elastic Beanstalk
Speech-to-text	Deepgram
AI note generation	Anthropic Claude
Error tracking	Sentry (PHI-scrubbed)
Audit/log shipping	AWS CloudWatch Logs

Key Integrations

- **Deepgram** — speech-to-text transcription (webhook/callback mode).
- **Anthropic Claude** — AI clinical-note drafting from transcripts.
- **AWS** — RDS (PostgreSQL), S3 (audio), CloudFront (CDN), Elastic Beanstalk (API host), CloudWatch (logs/metrics).

2. Architecture



Frontend Architecture

- **React 19** single-page app built with **Vite 8**, routed by **react-router-dom 7**, charts via **Recharts**.
- Built to static assets (**vite build -> dist/**) and served from **S3** behind **CloudFront**.
- Talks to the backend exclusively through the REST API base URL configured in **.env.production (VITE_API_URL)**.

Backend Architecture

- **Node.js 22 + Express 5** API, entry point **src/server.js**.
- Hardened with **helmet** (CSP, HSTS), explicit security headers, **CORS** allow-list, and **express-rate-limit** (global + stricter auth limiter).
- Schema is applied idempotently at startup (**ensureUserProfileSchema**) so fresh deploys have the required columns before serving traffic.
- Deployed on **AWS Elastic Beanstalk** with auto-scaling.

Database

- **PostgreSQL** managed by **AWS RDS** (`anot-postgres`).
- Encrypted at rest (AES-256), automated daily snapshots with point-in-time recovery.

Storage

- Audio recordings are stored in **S3** (`anot-audio-625242092266`) with **AES-256** server-side encryption. Audio is never served from a public URL — access is only via the authenticated `GET /api/audio/:visitId` route, which issues short-lived presigned URLs.

Deployment

- **Frontend:** S3 static hosting + CloudFront CDN/TLS.
- **Backend:** Elastic Beanstalk (auto-scaling Node.js environment).
- **Database:** RDS managed PostgreSQL.

3. System Components

Frontend (`anot-frontend-main`)

Property	Value
Technology	React 19, Vite 8, React Router 7, Recharts
Build	<code>npm run build</code> (outputs static assets to <code>dist/</code>)
Dev server	<code>npm run dev</code> (Vite, default port 5173)
Deploy	Upload <code>dist/</code> to S3, served via CloudFront
Config	<code>.env.production</code> (<code>VITE_API_URL</code>)

Styling note: the UI is built with utility CSS conventions; verify the exact toolchain in the frontend repo before changing the build. The deployable artifact is always the static `dist/` output from `vite build`.

Backend (`anot-backend-main`)

Property	Value
Technology	Node.js 22, Express 5
Entry point	<code>src/server.js</code> (<code>npm start</code>)
Database	PostgreSQL (RDS) via <code>pg</code> connection pool
Deploy	Elastic Beanstalk

Key route groups	<code>/api/auth, /api/visits, /api/notes, /api/users, /api/patients, /api/assignments, /api/audio, /api/audit, /api/settings, /api/support, /api/webhooks, /api/admin</code>
------------------	--

Mounted route map (`src/server.js`):

```

/api/auth      -> authentication, profile, password, PHI-training gate
/api/webhooks  -> Deepgram transcription callbacks
/api/users     -> user/staff management (admin portal)
/api/patients  -> patient records
/api/visits    -> visits, recording lifecycle, transcription triggers
/api/notes     -> note drafts, submit, approve, EHR upload, grading
/api/assignments -> scribe <-> clinician assignments
/api/audio     -> authenticated audio retrieval (presigned URLs)
/api/audit     -> audit log listing, summary, export, retention
/api/settings  -> system/AI settings (encrypted)
/api/support   -> support requests
/api/admin     -> system health dashboard (super_admin)

```

Database (PostgreSQL)

Property	Value
Host	<code>anot-postgres.c5casia24do8.ap-southeast-1.rds.amazonaws.com</code>
Application user	<code>anot_app</code>
Core tables	<code>users, patients, visits, notes, audit_logs, grades, scribe_assignments</code>
Backup	Automated daily RDS snapshots (7-day retention, PITR)
Encryption	At-rest AES-256

Note: the assignments table is named `scribe_assignments` (clinician <-> scribe), and the quality table is `grades`. See [§8 Database Schema](#) for the authoritative column lists.

Storage (S3)

Property	Value
Bucket	<code>anot-audio-625242092266</code>
Region	<code>ap-southeast-1</code>
Purpose	Store visit audio recordings
Lifecycle	Auto-delete after 90 days
Encryption	AES-256 (server-side, <code>ServerSideEncryption: AES256</code>)
Access	Private only — via authenticated <code>GET /api/audio/:visitId</code> with 7-day presigned URLs

API Services

- **Deepgram** — speech-to-text. Health-probed via **GET** <https://api.deepgram.com/v1/projects>.
- **Anthropic Claude** — AI note generation. Health-probed via **GET** <https://api.anthropic.com/v1/models>.
- **AWS** — RDS, S3, CloudFront, Elastic Beanstalk, CloudWatch Logs.

4. Deployment Architecture

Tier	Service	Notes
Frontend	CloudFront (CDN) + S3 (static hosting)	TLS termination at CloudFront; static dist/ in S3
Backend	Elastic Beanstalk	Auto-scaling Node.js environment; trusts 1 proxy hop in production
Database	RDS (managed PostgreSQL)	Daily snapshots, encryption at rest, PITR
Monitoring	CloudWatch + Sentry	App/EB logs in CloudWatch; error tracking (PHI-scrubbed) in Sentry

Request path: Browser -> CloudFront -> (static from S3) / (**/api/*** to the Elastic Beanstalk backend) -> RDS / S3 / Deepgram / Anthropic.

The frontend's production API base URL lives in **anot-frontend-main/anot-frontend-main/.env.production** (**VITE_API_URL**). The backend enforces a CORS allow-list (configurable via the **CORS_ORIGINS** env var) so only approved origins may call the API.

5. User Roles & Permissions

Roles are canonicalized in **src/utils/roles.js**. The hierarchy is **super_admin > admin > {clinician, scribe, qps}**.

Role	Capabilities
Super Admin	Full system access. Bootstrap-only role (never created via API). Can create admin accounts, manage all users, grant admin portal modules, view audit logs, apply audit retention, view performance reports, and access the System Health dashboard (/api/admin/health).
Admin	Create/manage non-elevated staff (clinician, scribe, qps), manage assignments, view audit logs, payroll, and settings — gated per-account by granted admin portal modules . Cannot manage super_admin ; can only manage other admin accounts if granted the admins module.

Clinician	Create and record visits, trigger transcription, view/edit and approve/lock their own notes, request edits, view their own note history.
Scribe	Review transcripts and AI drafts for assigned clinicians, save/submit drafts, trigger transcription/draft generation, upload approved notes to EHR, view their grades.
QPS	Quality & Performance Standards — grade/quality-check submitted notes (accuracy, completeness, terminology, formatting, overall), view performance reports.

Admin Portal Modules

Admin accounts are further scoped by **module keys** (granted by Super Admin): **overview**, **clinicians**, **scribes**, **qps**, **admins**, **assignments**, **payroll**, **audit**, **settings**, **system-profile**. When an admin's modules are unset (**null**), they receive all modules **except admins**. Module access is enforced by middleware (**requireAdminPortalModules**) and audited (**logAdminPortalModuleAccess**).

6. Key Workflows

6.1 User Login Flow

1. Client **POST** `/api/auth/login` with `{ email, password }`.
2. Server looks up the user, verifies the bcrypt password hash, and returns a **single generic error** (**Invalid email or password.**) for any credential/role/status failure to prevent account enumeration.
3. **Gates before a full session is issued:**
 - **Forced password change** (**force_password_change = true**) — temp passwords, admin resets, and seeds require the user to set a new password.
 - **PHI training gate** — if the account has not acknowledged the current PHI training revision (**phi_training_acknowledged / phi_training_version**), login returns a short-lived **temporaryToken**; the client must call **POST** `/api/auth/acknowledge-phi-training` to complete it.
4. On success, the server issues a **JWT** (**expiresIn** default **8h**, configurable via **JWT_EXPIRES_IN**) carrying **id**, **name**, **email**, **role**, **specialty**.
5. The login endpoint is brute-force protected (10 failed attempts / 15 min per IP; successful logins are not counted).

6.2 Recording an Encounter

1. Clinician creates a visit: **POST** `/api/visits` (patient, visit type, date/time).
2. Audio is recorded in the browser and uploaded against the visit; the audio file is stored in S3 (path saved on **visits.audio_file**).

3. Visit `transcription_status` tracks lifecycle: `idle -> processing -> completed`.

6.3 Transcription Pipeline

1. Trigger: `POST /api/visits/:id/transcribe` (or legacy `/generate-ai`), allowed for clinician/scribe.
2. The server validates audio exists, resolves any stuck `processing` state, then returns `202` and runs the AI pipeline asynchronously (`runAIPipeline`).
3. Audio is fetched from S3, sent to **Deepgram**; transcription completes via webhook (`/api/webhooks`) in callback mode. Segments are stored on `notes.transcription`.

6.4 AI Note Generation

1. With a transcript present, `generateAINote` calls **Anthropic Claude** with patient/visit context (name, MRN, visit type/date) to produce a structured draft.
2. The draft is stored on `notes.ai_draft`. If no Anthropic key is configured, a clear placeholder message is stored instead so the gap is visible in the editor.
3. Scribes can re-run draft generation via `POST /api/visits/:id/generate-draft` while the note is still `pending/draft` (locked notes return `409`).

6.5 Scribe Review

1. Scribe lists assigned work and opens the note (`GET /api/notes/visit/:visitId`).
2. Scribe edits and saves a working draft (`POST /api/notes/draft`).
3. When ready, scribe submits (`PUT /api/notes/:id/submit`) — status moves toward `submitted`.

6.6 Clinician Approval

1. Clinician reviews the submitted note, edits content (`PUT /api/notes/:id`), or requests changes (`PUT /api/notes/:id/request-edit`).
2. Clinician locks/approves the note (`POST /api/visits/:id/lock-note`), freezing further edits.

6.7 EHR Upload (Manual)

1. After approval, the note is uploaded to the EHR via `POST /api/notes/:id/upload-ehr`.
2. This records `ehr_uploaded_at` / `ehr_uploaded_by` and sets the note status to `uploaded`. **EHR upload is currently a manual action** (see [§14](#)).

6.8 Quality Grading (QPS)

1. QPS reviews submitted/uploaded notes and submits a grade (`POST /api/notes/grade`).
2. Grades capture `accuracy`, `completeness`, `terminology`, `formatting`, `overall_score`, and an optional `comment` (stored in the `grades` table, one row per note).

7. API Endpoints

All routes are prefixed with the API base URL (e.g. <https://<cloudfront-domain>/api>). Unless noted, endpoints require a valid JWT (**Authorization: Bearer <token>**) via the **protect** middleware, and role/module restrictions are enforced server-side. The global limiter allows 100 req/15min in production; </api/auth> is limited to 20 req/15min.

Authentication — </api/auth>

Method	Path	Access	Description
POST	/api/auth/login	Public (rate-limited)	Authenticate; returns JWT or a gate (force_password_change / PHI training temporaryToken)
POST	/api/auth/acknowledge-phi-training	Temp token (rate-limited)	Complete the PHI-training gate and issue a full session
POST	/api/auth/register	Admin, Super Admin	Create a new staff account
POST	/api/auth/logout	Authenticated	Record sign-out (client discards token)
GET	/api/auth/me	Authenticated	Get current user profile
PUT	/api/auth/me	Authenticated	Update current user profile
PUT	/api/auth/change-password	Authenticated (rate-limited)	Change own password

Visits — </api/visits>

Method	Path	Access	Description
GET	/api/visits/	Clinician, Scribe, QPS	List visits (scoped per role)
GET	/api/visits/my	Clinician	Today's visits by date
GET	/api/visits/history	Clinician	Visit history
POST	/api/visits/	Clinician	Create a visit
PUT	/api/visits/:id	Clinician	Update visit
PUT	/api/visits/:id/end	Clinician	End/finalize the encounter
PUT	/api/visits/:id/status	Clinician, Scribe	Update visit status
DELETE	/api/visits/:id	Clinician	Delete a visit
POST	/api/visits/:id/transcribe	Clinician, Scribe	Queue transcription
POST	/api/visits/:id/		

generate-ai

Clinician, Scribe	Legacy alias for transcribe
-------------------	-----------------------------

POST	<code>/api/visits/:id/generate-draft</code>	Scribe	Generate AI draft from saved transcript
POST	<code>/api/visits/:id/lock-note</code>	Clinician	Lock/approve the note

Notes — `/api/notes`

Method	Path	Access	Description
GET	<code>/api/notes/</code>	Admin, Super Admin, QPS	List all notes
GET	<code>/api/notes/my</code>	Scribe	Notes assigned to the scribe
GET	<code>/api/notes/clinician</code>	Clinician	Clinician's own notes
GET	<code>/api/notes/my-grades</code>	Scribe	Grades received on the scribe's notes
GET	<code>/api/notes/visit/:visitId</code>	Authenticated	Get the note for a visit
POST	<code>/api/notes/draft</code>	Scribe	Save a working draft
PUT	<code>/api/notes/:id</code>	Clinician	Update note content
PUT	<code>/api/notes/:id/submit</code>	Scribe	Submit note as ready
PUT	<code>/api/notes/:id/request-edit</code>	Clinician	Request changes
POST	<code>/api/notes/:id/upload-ehr</code>	Scribe	Mark note uploaded to EHR
POST	<code>/api/notes/grade</code>	QPS	Submit a quality grade

Users — `/api/users` (Admin portal, module-gated)

Method	Path	Access	Description
GET	<code>/api/users/</code>	Admin, Super Admin	List users
GET	<code>/api/users/stats</code>	Admin, Super Admin (<code>overview</code>)	Admin dashboard stats
GET	<code>/api/users/payroll</code>	Admin, Super Admin (<code>payroll</code>)	Payroll report
GET	<code>/api/users/performance</code>	QPS, Super Admin	Performance report
GET	<code>/api/users/role/:role</code>	Admin, Super Admin, QPS	List users by role
GET	<code>/api/users/:id</code>	Admin, Super Admin	Get a user

PUT	<code>/api/users/:id</code>	Admin, Super Admin	Update a user
PATCH	<code>/api/users/:id/ admin-modules</code>	Super Admin (admins)	Grant admin portal modules
PUT	<code>/api/users/:id/ toggle-status</code>	Admin, Super Admin	Disable/enable a user
PUT	<code>/api/users/:id/ reset-password</code>	Admin, Super Admin	Reset a user's password
PUT	<code>/api/users/:id/rate</code>	Admin, Super Admin	Set pay rate per note
DELETE	<code>/api/users/:id</code>	Admin, Super Admin	Delete a user

Assignments — `/api/assignments`

Method	Path	Access	Description
GET	<code>/api/assignments/</code>	Admin, Super Admin	List scribe<->clinician assignments
POST	<code>/api/assignments/</code>	Admin, Super Admin (assignments)	Assign a scribe to a clinician (reassigns existing open visits)
GET	<code>/api/assignments/ my-clinicians</code>	Scribe	Clinicians assigned to the scribe
DELETE	<code>/api/ assignments/:id</code>	Admin, Super Admin (assignments)	Remove an assignment

Audit — `/api/audit` (Admin/Super Admin, **audit** module)

Method	Path	Access	Description
GET	<code>/api/audit/</code>	Admin, Super Admin	List audit log entries
GET	<code>/api/audit/summary</code>	Admin, Super Admin	Audit summary/aggregates
GET	<code>/api/audit/export</code>	Admin, Super Admin	Export audit logs
POST	<code>/api/audit/retention/ apply</code>	Super Admin	Apply audit retention policy

Audio — `/api/audio`

Method	Path	Access	Description
GET	<code>/api/ audio/:visitId</code>	Authenticated (scoped)	Retrieve visit audio via a short-lived presigned S3 URL

Admin / System Health — `/api/admin`

Method	Path	Access	Description
GET	/api/admin/health	Super Admin	System health: probes DB, Deepgram, Anthropic, S3 (5-min cache) + live metrics

Other

Method	Path	Access	Description
GET	/	Public	Liveness check ({ status: 'healthy' })
*	/api/webhooks/*	Signed	Deepgram transcription callbacks
*	/api/patients/*	Authenticated	Patient records
*	/api/settings/*	Admin (settings)	Encrypted system/AI settings
*	/api/support/*	Authenticated	Support requests

8. Database Schema

The authoritative table definitions live in `scripts/bootstrap-local-schema.sql` (and migrations under `migrations/`). Profile/PHI/forced-password columns on `users` and the extended audit columns are applied idempotently at startup. The actual column names below differ from some informal descriptions — these are the real ones.

users

Column	Type	Notes
id	SERIAL PK	
name	TEXT	
email	TEXT UNIQUE	lowercased on login
password	TEXT	bcrypt hash
role	VARCHAR(32)	super_admin / admin / clinician / scribe / qps
specialty, phone, npa, license	TEXT	clinician profile fields
status	VARCHAR(24)	default active (disable/enable)
avatar_data_url, personal_info	TEXT	profile
admin_modules	JSONB	granted admin portal modules (null = all except admins)

rate_per_note	NUMERIC(10,2)	payroll rate
force_password_change	BOOLEAN	default false
phi_training_acknowledged	BOOLEAN	default false
phi_training_acknowledged_at	TIMESTAMPTZ	
phi_training_version	INTEGER	default 1
created_at	TIMESTAMPTZ	

patients

Column	Type	Notes
id	SERIAL PK	
name	TEXT	
mrn	TEXT UNIQUE	medical record number
date_of_birth	DATE	
created_at	TIMESTAMPTZ	

visits

Column	Type	Notes
id	SERIAL PK	
patient_id	INTEGER FK -> patients	
clinician_id	INTEGER FK -> users	
scribe_id	INTEGER FK -> users	nullable
visit_date	DATE	
visit_time	TEXT	
visit_type	VARCHAR(64)	Follow-up / New Patient / Virtual Visit / Other
status	VARCHAR(32)	default upcoming ; e.g. uploaded
duration_seconds	INTEGER	
audio_file	TEXT	S3 path (legacy /uploads/... format)
transcription_status	VARCHAR(32)	idle / processing / completed

<code>created_at</code>	TIMESTAMPTZ	
-------------------------	-------------	--

notes

Column	Type	Notes
<code>id</code>	SERIAL PK	
<code>visit_id</code>	INTEGER UNIQUE FK -> visits	one note per visit
<code>transcription</code>	TEXT	JSON-encoded transcript segments
<code>ai_draft</code>	TEXT	Anthropic-generated draft
<code>final_note</code>	TEXT	scribe/clinician final content
<code>status</code>	VARCHAR(32)	default <code>pending</code> ; <code>draft</code> / <code>submitted</code> / <code>uploaded</code>
<code>submitted_by</code>	INTEGER FK -> users	
<code>locked_at, locked_by</code>	TIMESTAMPTZ / INTEGER	approval lock
<code>ehr_uploaded_at, ehr_uploaded_by</code>	TIMESTAMPTZ / INTEGER	EHR upload audit
<code>created_at, updated_at</code>	TIMESTAMPTZ	

Naming note: the draft fields are `transcription`, `ai_draft`, and `final_note` (there is no separate `scribe_draft` column — the scribe edits `final_note`).

audit_logs

Column	Type	Notes
<code>id</code>	BIGSERIAL PK	
<code>user_id, user_name, user_role</code>	INTEGER / TEXT	actor
<code>action</code>	TEXT	e.g. <code>SCRIBE_ASSIGNED</code>
<code>entity_type, entity_id</code>	TEXT	target
<code>details</code>	TEXT	
<code>ip_address</code>	VARCHAR(64)	trusted <code>req.ip</code> , not spoofable
<code>user_agent, request_path</code>	TEXT / VARCHAR(512)	

status	VARCHAR(24)	success / warning / error / failure / critical
module_key, action_category	VARCHAR	admin portal context
event_metadata	JSONB	default {}
created_at	TIMESTAMPTZ	indexed DESC

grades

Column	Type	Notes
id	SERIAL PK	
note_id	INTEGER UNIQUE FK -> notes	one grade per note
qps_id	INTEGER FK -> users	grader
accuracy, completeness, terminology, formatting	INTEGER	sub-scores
overall_score	INTEGER	
comment	TEXT	
created_at	TIMESTAMPTZ	

scribe_assignments

Column	Type	Notes
id	SERIAL PK	
clinician_id	INTEGER FK -> users	
scribe_id	INTEGER FK -> users	
assigned_at	TIMESTAMPTZ	
		UNIQUE (clinician_id, scribe_id)

9. Security & Compliance

See [SECURITY_AND_COMPLIANCE_MANUAL.md](#), [HIPAA_COMPLIANCE_SIGN_OFF.md](#), [RISK_ASSESSMENT.md](#), and [BREACH_RESPONSE_PLAN.md](#) for the full compliance program.

HIPAA Compliance

- **Workforce training gate** — every user must acknowledge the current PHI awareness training revision before a full session is issued; bumping `PHI_TRAINING_VERSION` re-prompts all users.
- **Audit logging** — all PHI-touching and administrative actions are recorded in `audit_logs` with actor, IP, user agent, status, and module context. Logs are designed to be append-only and retained per the retention policy (target: **7 years**).
- **Encryption** — at rest (S3 AES-256, RDS at-rest) and in transit (TLS via CloudFront/HSTS).

Authentication

- **JWT** bearer tokens (`expiresIn` default **8h**, `JWT_EXPIRES_IN` configurable). `JWT_SECRET` is required at boot and must be "e16 characters in production.
- **bcrypt** password hashing (`bcryptjs`), enforced password policy, forced password change on reset/seed.
- Generic error messages on login to prevent account/role enumeration.

Authorization

- **Role-based access control** via `restrict(...)` middleware on every route.
- **Admin portal module** gating via `requireAdminPortalModules` for fine-grained admin scope.
- Visit/note access is scoped per role in the controllers (clinicians see their own, scribes see assigned, QPS sees review queue).

Network & Transport Hardening (`src/server.js`)

- **helmet** with a strict Content-Security-Policy, HSTS (1 year, `includeSubDomains`, `preload`).
- Explicit headers: `X-Content-Type-Options`, `X-Frame-Options: DENY`, `Referrer-Policy`, `Permissions-Policy` (microphone allowed for recording, camera/geolocation denied).
- **CORS** allow-list (no wildcard `*.vercel.app` regex); extra origins via `CORS_ORIGINS`.
- **Rate limiting**: 100 req/15min global, 20 req/15min on `/api/auth`, 10 failed logins/15min.
- JSON body limits (2 MB default, 15 MB for webhooks) with explicit 400/413 handling.
- `x-powered-by` disabled; trusts exactly 1 proxy hop in production for correct client IPs.

Audio Privacy

- Audio is never public. It is only retrievable through authenticated `GET /api/audio/:visitId`, which issues short-lived (7-day max) presigned S3 URLs.

Business Associate Agreements (BAAs)

BAAs are in place with sub-processors that may handle PHI: **AWS**, **Deepgram**, and **Anthropic**.

Breach Response

See `BREACH_RESPONSE_PLAN.md` for the incident detection, containment, notification, and post-incident procedures.

10. Configuration & Environment Variables

Frontend (`.env.production`)

Variable	Purpose	Example
<code>VITE_API_URL</code>	Backend API base URL	<code>https://d3t0m4s0ayca85.cloudfront.net/api</code>
<code>VITE_APP_NAME</code>	Display app name (optional)	<code>Anot Health</code>

Backend (Elastic Beanstalk environment)

Variable	Required	Purpose
<code>JWT_SECRET</code>	Yes	JWT signing key ("e16 chars in production)
<code>JWT_EXPIRES_IN</code>	No	Token lifetime (default <code>8h</code>)
<code>DATABASE_URL</code>	Yes	PostgreSQL connection string (RDS)
<code>DEEPGRAM_API_KEY</code>	Yes	Deepgram speech-to-text (or set in Admin -> Settings)
<code>ANTHROPIC_API_KEY</code>	Yes	Anthropic Claude (or set in Admin -> Settings)
<code>AWS_REGION</code>	Yes	AWS region (default <code>ap-southeast-1</code>)
<code>S3_AUDIO_BUCKET</code>	Yes	Audio bucket (default <code>anot-audio-625242092266</code>)
<code>SETTINGS_ENCRYPTION_KEY</code>	Yes	Encrypts stored system/AI settings (e.g. API keys)
<code>SENTRY_DSN</code>	No	Sentry error tracking endpoint
<code>CORS_ORIGINS</code>	No	Comma-separated additional allowed origins
<code>NODE_ENV</code>	Yes	<code>production</code> enables strict limits/headers
<code>PORT</code>	No	Listen port (default <code>5000</code>)
<code>TRUST_PROXY</code>	No	Proxy hops to trust (default 1 in production)
<code>AWS_ACCESS_KEY_ID</code> / <code>AWS_SECRET_ACCESS_KEY</code>	Local only	Used locally; in EB the instance profile provides credentials

Credentials in production come from the EB instance profile (AWS provider chain), so static access keys are only needed for local development. API keys for Deepgram/Anthropic can be provided either as env vars or via the encrypted Admin -> Settings store (`SETTINGS_ENCRYPTION_KEY`).

11. Monitoring & Logging

Layer	Tool	What it captures
Application & EB logs	CloudWatch Logs	Server logs, audit shipping (<code>initCloudWatch</code>), EB platform logs
Error tracking	Sentry	Unhandled errors and exceptions, PHI-scrubbed in <code>instrument.js</code> (<code>beforeSend</code>)
Database audit	<code>audit_logs</code> table	Every PHI/admin action with actor, IP, status, module context
System health	Admin -> System Health	<code>GET /api/admin/health</code> — live status of DB, Deepgram, Anthropic, S3 + metrics

System Health Dashboard

`GET /api/admin/health` (Super Admin) probes the four core dependencies with a 4-second timeout each, caches the probe results for 5 minutes, and rolls them into an overall status:

- `healthy` — all components OK
- `degraded` — exactly one component failing
- `critical` — two or more components failing

It also returns live DB-backed metrics: `totalUsers`, `activeSessions` (distinct users active in the last 15 minutes), `errorsLast24h`, and `apiCallsLast24h`.

12. Disaster Recovery

Full runbook: `docs/DISASTER_RECOVERY.md`.

Asset	Protection
RDS PostgreSQL	Automated daily snapshots, 7-day retention , point-in-time recovery (PITR)
S3 audio	11 nines (99.999999999%) durability; no single point of failure; 90-day lifecycle
CloudFront	Globally distributed CDN; resilient edge caching for the static frontend

Schema	Idempotent startup migrations recreate required columns on fresh deploys
--------	--

Recovery summary: restore RDS from snapshot or PITR, redeploy the EB backend (schema is re-applied at boot), and re-point CloudFront/S3 if needed. Follow [docs/DISASTER_RECOVERY.md](#) for the step-by-step procedure and RTO/RPO targets.

13. Cost Monitoring

Full guide: [docs/COST_MONITORING.md](#).

- **AWS budget: \$200/month** hard cap, with an alert at 80% (\$160). Target run-rate ~\$135/month.
- **Service breakdown (targets):** RDS ~\$50, EC2/Elastic Beanstalk ~\$50, S3 ~\$20, CloudFront ~\$10, other (CloudWatch/SNS) ~\$5.
- **Deepgram budget: 5,000 minutes/month** (~\$50), alert at 4,000 min.
- **Anthropic budget: 10M tokens/month** (~\$50), alert at 8M tokens.
- AI spend (Deepgram + Anthropic) is billed by the vendors and **does not** appear in AWS Cost Explorer — check their consoles separately.

14. Known Limitations & Future Work

Area	Current state	Future
EHR integration	Manual upload only (POST /api/notes/:id/upload-ehr records the action)	Automatic EHR push via integration API
Custom domain	Not yet configured (uses CloudFront default domain)	Custom domain pending TLS certificate
Real-time collaboration	Not available (one note per visit, sequential review)	Concurrent editing/presence
Mobile	Web-responsive only	Native mobile app

15. Troubleshooting

Common Issues

Symptom	Likely cause	Resolution
Login returns "Invalid email or password" for a valid user	Account disabled (status != active) or wrong role	Check users.status ; generic message hides the reason by design

Login asks for password change	<code>force_password_change = true</code>	Complete the change flow (<code>PUT /api/auth/change-password</code>)
Login blocked by training screen	PHI training not acknowledged for current version	Complete <code>POST /api/auth/acknowledge-phi-training</code>
Transcription stuck on <code>processing</code>	Prior run crashed / webhook unreachable	Re-trigger <code>POST /api/visits/:id/transcribe</code> — the server resets stuck state to <code>idle</code> and retries
AI draft shows "unavailable" placeholder	No Anthropic API key configured	Add <code>ANTHROPIC_API_KEY</code> or set it in Admin -> Settings, then re-run draft generation
<code>409 Note is locked</code>	Note already locked/ approved	A locked note cannot be re-drafted; request edit first
CORS error in browser	Origin not in allow-list	Add the origin to <code>CORS_ORIGINS</code>
<code>429 Too many requests</code>	Rate limit hit	Wait 15 minutes; check for retry loops
<code>400 Invalid JSON in request body</code>	Malformed request body	Fix the client payload

How to Check System Health

- **Super Admin** -> **System Health** in the app, or call `GET /api/admin/health`.
- Status `degraded/critical` indicates which dependency (DB, Deepgram, Anthropic, S3) is failing and why (e.g. "Invalid API key", "Bucket not found", "timed out").

How to Restart Services

- **Backend:** restart the Elastic Beanstalk environment (`eb restart` or via the EB console). Schema migrations re-run safely at boot.
- **Frontend:** re-run `npm run build` and re-upload `dist/` to S3, then invalidate the CloudFront cache.

How to Debug API Errors

1. Reproduce and capture the HTTP status + JSON `error` message.
2. Check **CloudWatch Logs** for the EB environment around the request time.
3. Check **Sentry** for the stack trace (PHI-scrubbed).
4. Cross-reference `audit_logs` for the actor/action context.

How to Access Production Logs

- **CloudWatch Logs** (AWS Console -> CloudWatch -> Log groups) for application/EB logs.

- **eb logs** from the EB CLI for the environment's recent platform/app logs.
- **Sentry** dashboard for error events.

16. Useful Links & References

Resource	URL
GitHub	https://github.com/1993ALINE/annot-health
Frontend repo path	<code>annot-frontend-main/annot-frontend-main</code>
Backend repo path	<code>annot-backend-main/annot-backend-main</code>
AWS Console	https://console.aws.amazon.com
Deepgram Console	https://console.deepgram.com
Anthropic Console	https://console.anthropic.com
Admin Panel	https://app.annot.health/admin
System Health	https://app.annot.health/admin/health

Companion docs: `docs/COST_MONITORING.md`, `docs/DISASTER_RECOVERY.md`, `docs/CLINICIAN_ONBOARDING.md`, `docs/ADMIN_ONBOARDING.md`, `SECURITY_AND_COMPLIANCE_MANUAL.md`, `HIPAA_COMPLIANCE_SIGN_OFF.md`, `BREACH_RESPONSE_PLAN.md`, `RISK_ASSESSMENT.md`, `PHI_TRAINING_ACKNOWLEDGMENT.md`, `PRIVACY_POLICY.md`, `TERMS_OF_SERVICE.md`.

17. Deployment Checklists

Pre-Deployment Checklist (before v37, v38, ...)

- [] All changes merged and CI green on the target branch.
- [] Version bumped and release notes drafted.
- [] Required env vars present in the EB environment (`JWT_SECRET`, `DATABASE_URL`, `DEEPGRAM_API_KEY`, `ANTHROPIC_API_KEY`, `AWS_REGION`, `S3_AUDIO_BUCKET`, `SETTINGS_ENCRYPTION_KEY`).
- [] `JWT_SECRET` is "e16 chars and `NODE_ENV=production`.
- [] Database migrations reviewed (startup schema is idempotent, but verify new migrations).
- [] Frontend `.env.production VITE_API_URL` points to the correct API base.
- [] Recent RDS snapshot confirmed (rollback safety).

Deployment Procedure (step-by-step)

1. **Backend:** build the deployable bundle and deploy to Elastic Beanstalk (`eb deploy`). Schema migrations apply automatically at startup before traffic is accepted.
2. **Frontend:** `npm run build`, upload `dist/` to the S3 static bucket.
3. **CloudFront:** create an invalidation (`/*`) so users get the new assets.
4. Confirm the backend liveness check (`GET /`) returns `{ status: 'healthy' }`.

Post-Deployment Verification

- [] `GET /` returns healthy and reports the expected version.
- [] `GET /api/admin/health` (Super Admin) shows all components `ok` (status `healthy`).
- [] Log in as each role and smoke-test the core workflow (record -> transcribe -> review -> approve).
- [] Spot-check CloudWatch and Sentry for new errors.
- [] Verify audit entries are being written for test actions.

Rollback Procedure (if needed)

1. **Backend:** redeploy the previous known-good application version in Elastic Beanstalk.
2. **Frontend:** re-upload the previous `dist/` build to S3 and invalidate CloudFront.
3. **Database:** if a migration caused the issue, restore from the pre-deployment RDS snapshot or use PITR (see `docs/DISASTER_RECOVERY.md`). Prefer forward-fixes over destructive restores.
4. Re-run the post-deployment verification checklist after rollback.

18. Contact & Support

Role	Contact
Technical lead	Atiqur Rahman — <code>admin@anot.health</code>
Support	<code>support@anot.health</code>
Privacy	<code>privacy@anot.health</code>
Emergency	+8801521434819

Admin Onboarding

Admin Onboarding Guide

Anot Health · Version 1.1 · June 16, 2026

Welcome. This guide walks administrators through the day-to-day tasks of running Anot Health: signing in, creating and managing staff, resetting passwords, reviewing audit logs, enabling/disabling accounts, monitoring system health, and troubleshooting common issues.

Roles at a glance: **super_admin** (platform governance, sole authority for audit retention purges and System Health), **admin** (day-to-day administration, scoped by granted portal modules), **clinician** (records encounters, reviews/locks notes), **scribe** (drafts notes, uploads to EHR), and **qps** (quality reviewer / grader). What you can see and do depends on your role and the admin portal modules granted to you.

A note on this guide: wording and labels below match the current build. Where a step depends on being a **super_admin**, it is called out explicitly.

1. Logging In

1. Open the application URL: <https://app.anot.health> (your CloudFront/app domain).
2. Enter your **email** (e.g. **atiquir@anot.health** or your assigned admin email) and **password**, then submit.
3. **First login (or after a password reset):** two modals appear in sequence before you reach the dashboard:
 - **Change Password modal** — set a new password with at least **12 characters** including an uppercase letter, a lowercase letter, a number, and a special character. Common/default passwords are rejected.
 - **PHI awareness training modal** — read and **acknowledge** the HIPAA/PHI training. This is required and is recorded in the audit log.
4. You land on the **admin dashboard** (it opens on the first module you have access to, e.g. **Overview**).

Sessions expire after **8 hours**; you'll need to sign in again after that. The sidebar lists only the modules your role/permissions allow.

2. Creating New Clinicians (and Other Staff)

Staff are managed under **per-role tabs** in the left sidebar — there is no single "Users" tab. Pick the tab for the role you're adding: **Clinicians**, **Scribes**, **QPS Staff**, or **Admins**.

To create a clinician:

1. In the sidebar, open the **Clinicians** tab.
2. Click **+ Add Clinician** (top-right of the table; if the list is empty, use the **Add Clinician** button in the empty state).
3. A **Register new Clinician** modal opens. Fill in:
 - **Role** — defaults to Clinician (you can switch to Scribe/QPS here; **Admin** appears only for super-admins).
 - **Full Name *** (required)
 - **Email *** (required, e.g. `name@anot.health`)
 - **Phone** (optional)
 - **Specialty** (optional, e.g. Internal Medicine)
 - **NPI Number** (optional, clinicians only)
 - **License** (optional, clinicians only)
 - **Initial password (optional)** — **leave this blank** so the system generates a secure temporary password.
4. Click **Create Clinician account** (the button label matches the selected role, e.g. "Create Scribe account"). Confirm the prompt.
5. The system shows the **temporary password once**. Use the **copy** action to copy it to your clipboard.
6. **Share it securely** with the clinician (in person, or via a secure channel your clinic approves). The clinician will be **forced to change it** on first login and must acknowledge PHI training.

Notes & limits:

- The new user is created **active**, with a forced password change + PHI training on first login.
- Only a **super_admin** can create **admin** accounts. The **super_admin** role cannot be created or assigned through the system.
- Admins can only add the staff roles their granted portal modules permit.
- Every creation is recorded in the audit log (**USER_REGISTERED**); the password is never logged.

3. Resetting Clinician (and Staff) Passwords

1. Open the relevant role tab (e.g. **Clinicians**) and find the user (use the search box if needed).
2. In that user's row, click **[x] Reset**
3. In the **Reset password** modal, click **Reset & generate password** and confirm.
4. The system generates a **random temporary password** and shows it **once** — copy it and share it securely with the user.

5. On their next login the user is **forced to change** the password and (if not already done) acknowledge PHI training.

Important: You cannot reset **your own** password this way (to avoid locking yourself out) — ask another admin. The reset is audited (`PASSWORD_RESET`); the password itself is never logged.

4. Viewing Audit Logs

Open the **Audit Logs** tab ([x] in the sidebar; requires the `audit` module permission).

1. **List / filter** audit events by **date range**, **action type** (login, create, delete, reset, etc.), **status**, **module**, and **user email**.
2. The **Summary** view surfaces indicators like failed-login counts and recent critical events — useful for a quick compliance/security pulse.
3. **Export** logs to **CSV / XLSX / PDF** when you need a record (exports are CSV-injection-safe).
4. Review entries for compliance and security investigations.

Audit logs are **append-only** — they cannot be edited or deleted outside the sanctioned retention purge. Retention is **7 years**. The **retention purge** (deleting records older than the window) is restricted to **super_admin** only and is itself audited.

5. Disabling / Enabling Users

1. Open the relevant role tab and find the user.
2. In the user's row, click **Disable** (for an active user) or **Enable** (for an inactive user). The status badge shows • **Active** or • **Inactive**.
3. Disabling a user blocks new logins and **revokes active sessions within ~60 seconds** (the auth cache is invalidated immediately on toggle). Re-enable the same way.

Notes:

- The **system Super Admin** account cannot be activated/deactivated here (the control is disabled on that row).
- Prefer **Disable** over deletion for anyone tied to clinical records — deletion is blocked when a user has linked visits/notes/grades (to prevent orphaned clinical data). Disabling preserves the audit and clinical trail.
- Status changes are audited (`USER_ACTIVATED` / `USER_DEACTIVATED`).

6. System Health Monitoring

Access: The **System Health** tab ([x] in the sidebar) **Super Admin-only**. Regular admins won't see it; the backend also enforces `super_admin`.

The page auto-refreshes every **30 seconds**; use **Refresh Now** for an immediate check.

1. Open the **System Health** tab.
2. Read the **overall status** orb at the top:
 - **Healthy (green)**: all systems operational.
 - **Degraded (yellow)**: at least one component is reporting an error.
 - **Critical (red)**: multiple components are down.
3. Review each **component card** — **Database**, **Deepgram**, **Anthropic**, and **S3** — each shows **Operational/Error**, **latency (ms)**, a status message, and when it was last tested.
4. Review the **Metrics** row: **Total Users**, **Active Sessions**, **Errors (24h)** (highlighted when > 0), and **API Calls (24h)**.
5. If status is **yellow/red**, check the failing component:
 - **Deepgram** -> transcription provider (API key/quota — see Settings and Troubleshooting).
 - **Anthropic** -> AI note generation provider (API key — see Settings).
 - **Database / S3** -> infrastructure; check provider status and recent deploys.
6. Click **Refresh Now** to re-run the checks after making a change.

Additional monitoring outside this tab: the backend health endpoint **GET /** returns **[x] Anot API is running** (via CloudFront, <https://<your-domain>/api/>). Application errors are reported to **Sentry** (PHI scrubbed) and operational logs ship to **CloudWatch**.

7. Troubleshooting Common Issues

Symptom	Likely cause	Fix
Clinician/staff can't log in	Account doesn't exist, is Inactive , or they haven't completed first-login steps	Confirm the user exists and is Active ; have them complete the forced password change + PHI training
"Account has been deactivated"	User status is inactive	Re-enable via Enable on the user's row
"Session expired. Please log in again."	Role changed, or token aged out (8h)	User signs in again
"Too many attempts" on login	Rate limit hit (20 / 15 min on auth)	Wait 15 minutes, then retry
Transcription not producing text	Deepgram API key missing/invalid or quota exceeded	Set/refresh the Deepgram API key in Settings ; check for 401 (bad key) or 429 (quota) in logs / System Health

"AI draft unavailable" in notes	Anthropic key missing or AI generation disabled	Add the Anthropic API key and enable AI generation in Settings
Deepgram call slow/stalled	Network/provider latency	Calls time out at 30s and retry with backoff; long sync transcriptions can raise deepgram_timeout_ms
System Health shows yellow/red	One or more components erroring	Open System Health , identify the failing component, fix it (key/infra), then Refresh Now
CORS / mixed-content errors in browser	Frontend built with wrong API URL, or CloudFront origin not allowed	Ensure frontend VITE_API_URL and backend CORS_ORIGINS match the CloudFront domain
Can't delete a user	User has linked clinical records	Disable instead of deleting

Escalation: For suspected security incidents or PHI exposure, follow **BREACH_RESPONSE_PLAN.md** and report immediately to **support@anot.health** (and **admin@anot.health** for urgent issues).

Support

- **Support:** support@anot.health
- **Administrator / Security Officer:** admin@anot.health
- **Privacy / Compliance:** privacy@anot.health

Clinician Onboarding

Clinician Onboarding Guide

Anot Health · Version 1.1 · June 16, 2026

Welcome to Anot Health. This guide gets you from your first login to recording visits, reviewing the AI-assisted note, and signing it off — with a few important privacy reminders along the way.

How it works: you **record** the encounter; Anot transcribes the audio and an AI drafts a structured note; your **scribe team** refines that draft; and **you review, edit, and lock** the final note. **You remain in control** — nothing is final until you lock it.

A note on this guide: labels and steps below match the current build. Where a feature you might expect isn't available yet, it's called out honestly so you're not left looking for it.

1. First Login (Important!)

1. Go to <https://app.anot.health>.
2. Enter your **email** (e.g. `name@anot.health`).
3. Enter the **temporary password** your administrator gave you.
4. **Change Password modal** appears.
 - Enter a new password: **12+ characters**, with an **uppercase** letter, a **lowercase** letter, a **number**, and a **symbol**. Common/default passwords are rejected.
 - Example shape (don't reuse this one): `MyClinic@2026`
 - Click to **change your password**.
5. **PHI Training modal** appears.
 - Read the HIPAA/PHI awareness training carefully. It covers:
 - What **PHI** (Protected Health Information) is
 - How Anot handles PHI securely
 - **Your responsibilities** as a clinician
 - The **90-day audio retention** policy
 - **Acknowledge** it and proceed. (This is a HIPAA requirement and is recorded.)
6. You're now in your **dashboard**. [x]

Keep your password private and never share your account. Your session lasts **8 hours** before you need to sign in again. If you ever suspect someone else accessed your account, tell your administrator and email support@anot.health right away.

2. Recording a Clinical Note

1. From your **schedule/dashboard**, open the encounter (select or create the patient / visit).
2. Click **Record Encounter** (or **Record Now** on an overdue visit).
3. Allow **microphone access** when your browser asks.
4. Speak naturally. The on-screen indicator shows **Recording live...** and a running timer.
5. You can **pause** and resume, and add an **Additional Recording** to the same visit if needed — recordings are kept in order.
6. Click % **Stop** when you're done.
7. The audio **uploads securely** (encrypted in transit and at rest). If your connection drops, the recording is saved in the tab and **retries automatically** — keep the tab open until it finishes.

Heads-up: the transcript does **not** appear live while you speak. Transcription runs **after** the audio uploads (see the next section). Record in a reasonably quiet room and confirm the recording indicator is active before the conversation starts.

3. Deepgram Transcription

- After the audio uploads, it's sent securely to **Deepgram**, our speech-to-text partner (covered by a signed Business Associate Agreement), using a medical-tuned model.
- This is **automatic** and **asynchronous** — it usually completes shortly after upload; larger recordings take a little longer. The visit shows a transcription status badge as it progresses.
- The transcript may contain small errors; these get refined in the note (next steps).
- If the transcript doesn't appear, check with your administrator — the most common cause is an API key/quota issue on the account.

4. Claude AI Note Generation

- Once a transcript exists, Anot sends it to **Anthropic's Claude** (also under a signed BAA, with zero data retention) to generate a **draft clinical note**.
- The draft uses a consistent structure:
 - **Chief Complaint**
 - **History of Present Illness (HPI)**
 - **Physical Examination (PE)**
 - **Imaging**
 - **Assessment & Plan (A&P)**

- The AI only uses what's in the transcript and writes **"Not mentioned"** where information is missing — it does **not** invent clinical details.
- Your **scribe team** works from this AI draft to prepare the note you'll review. In the clinician view this appears as the **"Scribe draft"** (alongside the **"Transcript"** tab).
- If AI generation is unavailable, you may see an **"AI draft unavailable"** placeholder — the scribe can still draft from the transcript.

Always review the draft. AI output is a starting point, not a final record. You are responsible for the accuracy of any note you finalize.

5. Reviewing & Editing the Note

1. Open the visit's note from your **Notes** screen (the status will read something like **Scribe draft ready**). You'll see the **Scribe draft** and the **Transcript** tabs.
 2. **Review** the scribe-prepared note for accuracy and completeness.
 3. **Edit** directly when needed:
 - Fix any transcription errors carried into the note
 - Add missing clinical information
 - Adjust clinical language and rewrite sections as your judgment requires
 4. Double-check accuracy and completeness before finalizing.
-

6. Approving (Locking) the Note

1. When the note is accurate and complete, choose to **Lock Note**.
2. A confirmation appears: locking **marks the note as completed and approved**, and **the scribe can no longer edit it**.
3. Confirm **Lock Note**. The note's status updates to reflect completion.

This is your sign-off. Treat locking as final approval of the clinical content.

7. Uploading to EHR (Manual Process)

Important: Anot does **not** automatically transmit notes into your external EHR. The **"Upload to EHR"** action in Anot only **marks a finalized note as uploaded** (recording when and by whom) for your team's tracking.

In the standard workflow, your **scribe team** marks the note **Uploaded to EHR** in Anot after it's finalized. The actual transfer into your EHR is a **manual** step done by whoever owns that in your clinic:

1. Open the finalized/locked note and review the content.

2. **Manually copy** the note text into your EHR (or follow your clinic's established process / export it per your clinic's policy).
3. Log into your EHR, find the patient record, create the note entry, paste the content, and submit.
4. Back in Anot, the note is marked **Uploaded to EHR** so the team knows it's been transferred.

If your organization later enables a direct EHR integration, this guide will be updated.

8. Audio & Data Privacy

- Everything you record and document is **Protected Health Information (PHI)**. Access only what you need for the patient in front of you ("minimum necessary").
 - **Encounter audio is automatically deleted after 90 days.** Transcripts and finalized notes are retained securely (encrypted) as part of the clinical record.
 - Don't copy PHI to personal devices, personal email, or messaging apps. Lock your screen when you step away, and log out on shared devices.
 - You can request deletion of your data — contact privacy@anot.health.
 - If you suspect a privacy or security problem (lost device, shared password, suspicious login, data sent to the wrong place), **report it immediately** — don't try to fix it quietly. See the PHI training ([PHI_TRAINING_ACKNOWLEDGMENT.md](#)) for details.
-

9. Getting Help

- **System issues / general support:** use the in-app support/contact option, or email support@anot.health.
 - **HIPAA / privacy questions:** privacy@anot.health
 - **Urgent / security:** admin@anot.health
 - **Feedback / feature requests:** feedback@anot.health
-

10. Settings & Preferences

- Open your **profile** from the sidebar to view your account.
 - **Change your password anytime** from the login screen flow or by asking your administrator to reset it.
 - Ask your administrator to update your contact details (name, email, phone, specialty), since staff records are managed in the Admin portal.
-

11. Keyboard Shortcuts

The current build keeps shortcuts minimal:

- **t** — on the **schedule** screen, jump back to **Today**.

Dedicated record/approve/edit shortcuts (e.g. R/A/E) and a global help shortcut are **not available yet**. Use the on-screen buttons described above. This section will be updated if shortcuts are added.

Disaster Recovery

Disaster Recovery Plan

Anot Health · Version 1.0 · June 16, 2026

This document describes how Anot Health protects its production PostgreSQL database against data loss and how to recover it after a corruption, accidental deletion, or infrastructure failure. It covers automated backups, point-in-time recovery (PITR), recovery objectives, the monthly backup test, and the emergency recovery procedure.

Audience: `super_admin` operators and infrastructure owners with AWS Console access to the production account. Recovery actions create or modify production infrastructure and must only be performed by authorized personnel.

Production references:

- RDS instance: `anot-postgres` (PostgreSQL)
- Application host: AWS Elastic Beanstalk (env var `DATABASE_URL`)
- Frontend: CloudFront -> backend API
- Audio storage: S3 bucket (`S3_AUDIO_BUCKET`) — backed up independently of the database

1. RDS Automated Backups

Amazon RDS takes a daily automated snapshot of the `anot-postgres` instance and continuously archives transaction logs, which together enable point-in-time recovery.

Verify automated backups are enabled

1. Open the **AWS Console** -> **RDS** -> **Databases**.
2. Select the `anot-postgres` instance.
3. Open the **Maintenance & backups** tab.
4. Under **Backup**, confirm:
 - **Automated backups:** `Enabled`
 - **Backup retention period:** `7 days`
 - **Backup window:** a defined daily window (e.g. a low-traffic UTC window)
 - **Latest restorable time:** within the last few minutes (confirms log archiving is healthy)

If automated backups show `Disabled`, enable them immediately:

- Click **Modify**, set **Backup retention period** to `7 days` (range 1–35; `0` disables backups), choose a backup window, then **Continue** -> **Apply immediately**.

Retention: 7 days is the standard for Anot Health. Increase it via the same **Modify** screen if your compliance window requires longer retention. Longer retention increases backup storage cost.

Access backups in the AWS Console

- **Automated snapshots & PITR window:** RDS -> Databases -> **anot-postgres** -> **Maintenance & backups**.
- **All snapshots (automated + manual):** RDS -> **Snapshots**. Filter by instance **anot-postgres**. Automated snapshots are named **rds:anot-postgres-YYYY-MM-DD-HH-MM**.
- **Take a manual snapshot anytime:** select the instance -> **Actions** -> **Take snapshot**. Manual snapshots are **not** deleted when the retention window passes (they persist until you delete them).

2. Point-in-Time Recovery (PITR)

Definition: PITR restores the database to **any second within the retention window** (up to the **latest restorable time**, typically ~5 minutes ago). RDS does this by restoring the most recent daily snapshot and replaying archived transaction logs up to your chosen timestamp. The restore always creates a **brand-new instance** — your existing instance is never modified.

Steps to perform PITR

1. Go to the **AWS Console** -> **RDS**.
2. Select the **anot-postgres** instance.
3. Click **Actions** -> **Restore to point in time**.
4. Choose the **recovery time**:
 - **Latest restorable time** (most recent safe point), or
 - **Custom** — enter the exact date/time (in your console timezone) to restore to. Pick a time **just before** the incident (e.g. before an accidental delete) to avoid replaying the bad change.
5. Configure the **new DB instance**:
 - **DB instance identifier:** e.g. **anot-postgres-restore-YYYYMMDD**.
 - Match the **instance class**, **storage**, **VPC/subnet group**, and **security group** of production so the application can reach it.
 - Confirm **Encryption** is enabled (a restore of an encrypted source is encrypted).
6. Click **Restore to point in time** and wait for the new instance to reach **Available** (typically 15–45 minutes depending on database size).
7. **Cut over the application:** update the Elastic Beanstalk **DATABASE_URL** environment variable to the **new instance endpoint** (Console -> Elastic Beanstalk -> environment -> **Configuration** -> **Software** -> **Environment properties**). Apply the change; EB restarts the app against the restored DB.

■

- The connection string format is: `postgres://<user>:<password>@<new-endpoint>:5432/<dbname>?sslmode=require`
8. **Verify** (see [§5 Emergency Recovery](#)) before announcing recovery complete.
 9. Once verified and stable, decommission the old/corrupted instance (take a final manual snapshot first if it may be needed for forensics).

3. Recovery Targets

Objective	Target	Meaning
RPO (Recovery Point Objective)	1 hour	Maximum acceptable data loss. RDS continuous log archiving keeps the latest restorable time within minutes, so realistic data loss is far below 1 hour.
RTO (Recovery Time Objective)	2 hours	Maximum acceptable time from incident declaration to a verified, serving database. Includes restore time, cutover, and verification.

These targets assume a single-region recovery using PITR/automated backups. If actual restore time trends toward RTO during a monthly test, consider a larger instance class for faster restores or a standby replica.

4. Monthly Backup Test

Run a non-destructive recovery drill on the **first Monday of each month** to prove backups are valid and the team can meet RTO/RPO. This uses a throwaway instance and never touches production.

1. **Perform a test restore** to a point-in-time from **~24 hours ago** (see [§2](#)). Name the instance `anot-postgres-drtest-YYYYMMDD`. **Do not** repoint production `DATABASE_URL` at it.
2. **Verify data integrity** against the restored instance (connect with a read-only client):
 - `SELECT COUNT(*) FROM users;` — row count is sane / matches expectations for that time.
 - `SELECT MAX(created_at) FROM audit_logs;` — confirms the data is from ~24h ago, as expected.
 - Spot-check a recent visit/note record to confirm referential integrity.
3. **Delete the test instance:** RDS -> select `anot-postgres-drtest-YYYYMMDD` -> **Actions -> Delete**. Decline the final snapshot prompt (it's a disposable test instance) to avoid storage cost.
4. **Document test completion** in the log below: date, who ran it, restore time achieved, row counts observed, and any issues.

Backup test log

Date	Performed by	Restore time	users count	Result / notes
YYYY-MM-DD	name	achieved e.g. 38 min	e.g. 142	Pass / issues

5. Emergency Recovery

Use this when production data is lost, corrupted, or the instance is unavailable.

- **Primary contact:** `admin@anot.health`
- **Declare the incident** and record the start time (RTO clock starts here).

Procedure

1. **Stop further writes** if data is being corrupted (e.g. temporarily scale the app down or put it in maintenance) to prevent the bad state from spreading.
2. **Choose the recovery source:**
 - **Accidental delete / corruption with a known time:** use **PITR** to a timestamp **just before** the incident ([S2](#)).
 - **Instance/host failure with no bad data:** restore the **latest automated backup** (RDS -> Snapshots -> latest `rd:anot-postgres-...` -> **Restore snapshot**), or PITR to **latest restorable time** for the smallest data loss.
3. **Cut over** the application by updating Elastic Beanstalk **DATABASE_URL** to the restored instance endpoint and applying the change.
4. **Verify** before declaring recovery complete:
 - `SELECT COUNT(*) FROM users;` — confirms the users table is present and populated.
 - Confirm a known recent user/visit exists and the app can log in and load the dashboard.
5. **Announce recovery** and record the end time. Capture RPO (data loss window) and RTO (elapsed time) for the post-incident review.
6. **Post-incident:** take a manual snapshot of the recovered instance, document root cause, and update this plan if any step was unclear or slow.

6. Backup Storage

- **Where:** RDS automated backups and snapshots are stored by AWS in **Amazon S3**, managed entirely by RDS (not visible as objects in your own S3 buckets).
- **Encryption:** backups are **encrypted at rest** using the same KMS key as the production database — a restore of an encrypted instance is always encrypted. No additional action is required.
- **Retention: 7 days** for automated backups (configurable 1–35 days via RDS -> **Modify**). Manual snapshots persist until explicitly deleted.

- **Audio (S3):** patient audio in the `S3_AUDIO_BUCKET` is a separate data store with its own bucket encryption and lifecycle policy; it is **not** included in RDS backups. Ensure S3 versioning and/or cross-region replication is enabled on that bucket if audio is in scope for recovery.

7. Quick Reference

Item	Value
Production DB instance	<code>anot-postgres</code>
Backup retention	7 days
RPO / RTO	1 hour / 2 hours
Monthly test	First Monday
App DB config	Elastic Beanstalk env var <code>DATABASE_URL</code>
Verify command	<code>SELECT COUNT(*) FROM users;</code>
Emergency contact	<code>admin@anot.health</code>

Cost Monitoring

Cost Monitoring Guide

Anot Health · Version 1.0 · June 16, 2026

This document describes how Anot Health tracks and controls its monthly cloud and AI spend. It covers the AWS budget alert, the expected per-service cost breakdown, third-party AI usage monitoring (Deepgram and Anthropic), how to check current spend, the monthly cost report procedure, and ongoing optimization practices.

Audience: `super_admin` operators and the finance/infrastructure owner with AWS Billing and third-party console access. Budget and billing changes affect the whole account and should only be made by authorized personnel.

Spending guardrails at a glance:

- **Hard cap:** \$200/month (AWS budget)
- **Alert trigger:** 80% -> \$160/month
- **Target run-rate:** ~\$135/month (AWS) + AI usage within budget
- **Owner / notifications:** `admin@anot.health`

1. AWS Budget Alert

Set up a monthly cost budget so the team is notified before spend approaches the \$200 cap.

Set up a \$200/month budget with an 80% alert

1. Open the **AWS Console** -> **Billing and Cost Management** -> **Budgets**.
2. Click **Create budget**.
3. Choose **Use a template (simplified)** -> **Monthly cost budget** (or **Customize (advanced)** for a cost budget).
4. Configure:
 - **Budget name:** `anot-monthly-cap`
 - **Period:** Monthly
 - **Budget amount:** **\$200** (fixed)
5. Configure the **alert threshold**:
 - Trigger at **80% of budgeted amount** -> **\$160** (actual spend).
 - Recommended: add a second alert at **100% (\$200)** and a **forecasted** alert at 100% for early warning.

6. **Notification:** email to **admin@anot.health**.
7. Click **Create budget**.

Note: AWS Budgets evaluates a few times per day, so alerts are near-real-time, not instant. The first notification can take up to ~24 hours after the budget is created.

2. Service Cost Breakdown

Expected steady-state AWS spend. These are planning targets, not hard limits — reconcile against **Cost Explorer** monthly (see [§5](#)).

Service	Role	Target / month
RDS	PostgreSQL database (anot-postgres)	~\$50
S3	Audio storage (S3_AUDIO_BUCKET)	~\$20
EC2 / Elastic Beanstalk	Backend API host	~\$50
CloudFront	Frontend / API distribution	~\$10
Other	SNS, CloudWatch, misc.	~\$5
Total (AWS)		~\$135

Buffer: the ~\$135 target leaves ~\$65 of headroom below the **\$200** cap to absorb traffic spikes and growth. AI usage (Deepgram + Anthropic) is billed by their respective vendors, **not** AWS — see [§3](#) and [§4](#).

3. Deepgram Usage Monitoring

Deepgram powers audio transcription and is billed by minutes transcribed.

- **Console:** <https://console.deepgram.com/usage>
- **Metric to watch:** minutes transcribed per month
- **Budget:** 5,000 minutes/month (~\$50 at standard rates)
- **Alert threshold:** if usage exceeds **4,000 minutes/month** (80%), review usage and projected end-of-month total before it crosses budget.

What to do when usage is high

- Confirm spikes correspond to real visit volume (not retries or stuck jobs).
- Verify transcription uses **webhook/callback mode** (see [§7](#)) so failed or retried jobs aren't double-charged.

4. Anthropic API Usage Monitoring

Anthropic powers AI note generation and is billed by tokens consumed.

- **Track: tokens used per month** (input + output) via the Anthropic Console usage/billing page.
- **Budget: 10M tokens/month** (~\$50)
- **Alert threshold:** if usage exceeds **8M tokens/month** (80%), review usage.
- **Optimize:** cache identical/repeated requests where possible to avoid re-spending tokens on the same input (see [§7](#)).

5. How to Check Current Spend

1. Open the **AWS Console -> Billing and Cost Management -> Cost Explorer**.
2. **Group by / filter by Service** (RDS, S3, EC2, CloudFront, etc.).
3. Set the **date range** to **This month** (month-to-date).
4. **Compare** current month-to-date spend and the **forecasted** month-end total against the **\$200** budget and the per-service targets in [§2](#).
5. For AI spend, check the Deepgram and Anthropic consoles separately — these do not appear in AWS Cost Explorer.

6. Monthly Cost Report Procedure

Run on the **first day of each month** for the prior month.

1. **Run the cost analysis** in Cost Explorer (prior month) and pull Deepgram + Anthropic usage totals.
2. **Document:** total spend, breakdown by service, AI minutes/tokens used, and variance vs budget.
3. **Share** the report with the **CEO / stakeholders**.
4. **Store** the report in the **Google Drive compliance folder**.
5. **Alert/act:** if total spend exceeded **\$160**, investigate the driver and apply optimizations from [§7](#).
Record the action taken in the log below.

Monthly cost report log

Month	Prepared by	AWS total	Deepgram (min)	Anthropic (tokens)	Over \$160?	Notes / action
YYYY-MM	name	\$	min	tokens	Y/N	link to report

7. Cost Optimization Tips

Area	Optimization	Status
S3 audio	Lifecycle rule deletes audio after 90 days	Enabled [x]
Deepgram	Use webhook/callback mode (instant response, no polling)	Recommended
Anthropic	Cache identical requests to reduce repeated token spend	Recommended
RDS	Monitor and close idle/unused connections ; right-size instance	Ongoing
CloudFront	Tune cache TTLs for static assets to maximize cache hit ratio	Ongoing
Elastic Beanstalk	Use auto-scaling to match capacity to real traffic	Ongoing

8. Quick Reference Table

Update monthly with actual spend from [§5](#) and [§6](#).

Service	Monthly Budget	Current Spend	Alert Level	Owner
AWS Total	\$200	TBD	\$160	Admin
RDS	\$50	TBD	\$40	Admin
S3 Audio	\$20	TBD	\$15	Admin
Deepgram	\$50	TBD	\$40	Admin
Anthropic	\$50	TBD	\$40	Admin

Contact / notifications: admin@anot.health

Security & Compliance Manual

Anot Health — Security & Compliance Manual

Document Owner: Anot Health **Classification:** Internal — Confidential **Version:** 1.0 **Effective Date:** June 14, 2026 **Next Review:** June 14, 2027 (annual, or upon material change) **Regulatory Scope:** HIPAA Privacy Rule (45 CFR Part 164, Subpart E), HIPAA Security Rule (45 CFR Part 164, Subpart C), HIPAA Breach Notification Rule (45 CFR §§164.400–414)

1. Executive Summary

Anot Health operates a clinical documentation platform that captures, transcribes, and stores patient encounter audio and AI-generated clinical notes. Because this data constitutes Protected Health Information (PHI), Anot Health maintains administrative, physical, and technical safeguards designed to satisfy the HIPAA Security Rule (45 CFR §164.302–318) and Privacy Rule.

This manual documents the security program as **implemented and verified in production**, not as aspiration. Key control highlights:

Control Area	Implementation	Status
Encryption at rest (database)	Amazon RDS / managed PostgreSQL with storage-level encryption	Active
Encryption at rest (audio)	Amazon S3 with AES-256 server-side encryption	Active
Encryption in transit	TLS 1.2+ for all client/server and service-to-service traffic	Active
Audit logging	Append-only <code>audit_logs</code> table enforced by database triggers	Verified active
Audit retention	7 years (2,555 days), HIPAA §164.316(b)(2) floor of 6 years exceeded	Active
Audio retention	90 days, then automated deletion	Active
Access control	Role-based (admin / super_admin / clinician / scribe)	Active
Brute-force protection	Rate limiting on authentication endpoints	Active
Business Associate Agreements	Signed with Deepgram and Anthropic	Executed

Error monitoring	Sentry with PHI scrubbing enabled	Active
------------------	-----------------------------------	--------

The remainder of this manual details privacy practices, the end-to-end data lifecycle, incident response, access control, and audit/monitoring procedures.

2. Privacy Practices

2.1 Data Types We Process

Category	Examples	Sensitivity
PHI — Audio	Recorded patient encounter audio	High
PHI — Clinical text	Transcriptions, AI draft notes, finalized clinical notes	High
PHI — Demographic	Patient identifiers associated with a visit	High
Workforce identity	User accounts, names, email addresses, roles	Moderate
Operational metadata	Audit logs, IP addresses, user-agent strings, timestamps	Moderate
System configuration	Encrypted API keys and integration settings	High

Anot Health collects only the minimum data necessary to deliver clinical documentation services, consistent with the HIPAA **Minimum Necessary** standard (§164.502(b)).

2.2 Retention Schedule

Data Type	Retention Period	Enforcement
Encounter audio (S3)	90 days , then deleted	Lifecycle / application deletion
Audit logs	7 years (2,555 days)	Append-only table + sanctioned retention purge
Clinical notes / visit records	Retained for the life of the clinical record per provider obligation	Application-managed
Workforce accounts	Duration of employment/engagement + deprovisioning on termination	Administrative

The audit retention floor is clamped to **2,190 days (6 years)** minimum and **3,650 days (10 years)** maximum at runtime, guaranteeing the HIPAA §164.316(b)(2) six-year minimum is never violated by misconfiguration.

2.3 Deletion Practices

- **Audio:** Deleted from S3 90 days after capture, and immediately (best-effort) when an associated visit is deleted.
- **Audit logs:** Cannot be edited or arbitrarily deleted. The **only** sanctioned deletion path is the retention purge, which removes records strictly older than the configured retention window and is restricted to the Super Admin role. The purge itself is recorded as an audit event (**AUDIT_RETENTION_APPLIED**).
- **Visit / clinical records:** Deletion is an authorized, audited action (**VISIT_DELETED**) and cascades to associated audio cleanup.

3. Data Handling Procedures (Collection -> Storage -> Access -> Deletion)

3.1 Collection

1. A clinician/scribe records encounter audio through the Anot application over a TLS-encrypted connection.
2. The act of creating a visit is captured as an audit event (**VISIT_CREATED**).
3. Only data necessary for transcription and note generation is collected (Minimum Necessary).

3.2 Processing & Sub-processors

1. Audio is sent to **Deepgram** for transcription under a signed **Business Associate Agreement (BAA)**.
2. Transcripts are processed by **Anthropic** to generate draft clinical notes, also under a signed **BAA**.
3. Service-to-service communication occurs over encrypted channels. Third-party API credentials are stored encrypted in system settings.

3.3 Storage

Asset	Location	Protection
Audio files	Amazon S3 (anot-audio-* bucket)	AES-256 server-side encryption ; private bucket; access only via short-lived presigned URLs
Database (PHI, notes, users, audit)	Amazon RDS / managed PostgreSQL	Encryption at rest ; network-restricted
Audit trail	audit_logs table	Append-only , trigger-enforced; tamper-resistant

Audio is **never** served from a public URL. It is accessible only through the authenticated, authorized endpoint **GET /api/audio/:visitId**, which issues time-limited presigned S3 URLs.

3.4 Access

- All API access requires authentication (`protect` middleware) and passes role restriction checks (`restrict(...)`) plus, for the admin portal, module-level permission checks (`requireAdminPortalModules(...)`).
- Every PHI read (e.g. viewing visits or visit history) is captured as an audit event (`VISITS_VIEWED`, `VISIT_HISTORY_VIEWED`).
- IP addresses in the audit trail are captured from the trusted `req.ip` (honoring `trust proxy = 1`), **not** from spoofable `X-Forwarded-For` headers.

3.5 Deletion

- Audio: time-based (90 days) and event-based (visit deletion) removal from S3.
- Audit logs: only via the sanctioned, role-restricted, audited retention purge after 7 years.
- Workforce: accounts are deprovisioned on termination; deletion is audited (`USER_DELETED`).

4. Incident Response Plan

For the full operational playbook, see `BREACH_RESPONSE_PLAN.md`. This section defines roles and the escalation ladder.

4.1 Objectives

Detect, contain, eradicate, and recover from security incidents; notify affected parties and regulators within legally required timelines; and improve controls post-incident.

4.2 Severity Classification

Severity	Definition	Example
SEV-1 (Critical)	Confirmed or likely PHI exposure	Unauthorized DB/S3 access, leaked credentials with data access
SEV-2 (High)	Security control failure without confirmed exposure	Failed audit-write spikes, repeated auth abuse
SEV-3 (Moderate)	Suspicious activity, no confirmed impact	Anomalous login patterns
SEV-4 (Low)	Policy deviation, no security impact	Misrouted internal report

4.3 Escalation Ladder

1. **Discovery** -> Anyone who detects an incident reports immediately to **support@anot.health**.
2. **Triage (within 1 hour)** -> Security/On-call lead classifies severity.
3. **Escalation (SEV-1/SEV-2)** -> Notify the **Security Officer / Administrator** at **admin@anot.health**

4. **Containment** -> Authorized administrators isolate affected systems and revoke credentials.
5. **Notification decision** -> Security Officer determines breach status and notification obligations.
6. **Closure** -> Post-incident review filed; corrective actions tracked to completion.

4.4 Mandatory Timelines

- **Patient notification:** without unreasonable delay and **no later than 60 days** after discovery (Anot targets initiation within **30 days**).
- **HHS notification:** within 60 days for breaches affecting **500+ individuals**; annual log for smaller breaches.

5. Access Control Policy

Anot Health enforces **role-based access control (RBAC)** with least-privilege defaults. PHI access is restricted to authenticated users whose role and module permissions authorize the specific action.

5.1 Role Definitions

Role	Purpose	Typical Permissions
super_admin	Highest privilege; platform governance	Full administrative access; sole authority to apply audit retention purges; manage all users and settings
admin	Day-to-day administration	Manage users, view audit logs/exports, configure non-destructive settings, access admin portal modules
clinician	Licensed provider	Create/conduct visits, record audio, view and finalize their clinical notes
scribe	Documentation support	Assist with notes for assigned visits within granted scope

5.2 Enforcement Mechanics

- **Authentication:** **protect** middleware validates the session/token on every protected route.
- **Authorization:** **restrict('admin','super_admin', ...)** gates role-sensitive routes; the audit API additionally requires the **audit** portal module permission.
- **Sensitive operations:** Retention purge is hard-restricted to **super_admin** (returns 403 otherwise).
- **Account lifecycle:** Creation (**USER_REGISTERED**), modification (**USER_UPDATED**), and removal (**USER_DELETED**) are all audited.

5.3 Authentication Hardening

- **Rate limiting on authentication endpoints** to slow brute-force attempts:
 - **20 attempts per 15 minutes on all authentication endpoints** (`/api/auth/*`).
 - This includes login, password reset, and all credential-related requests.
- General API rate limiting is also applied platform-wide.
- All authentication events are audited: `LOGIN_SUCCESS`, `LOGIN_FAILED`, `LOGOUT`, `SELF_PASSWORD_CHANGED`, `PASSWORD_RESET`.

6. Audit & Monitoring Procedures

6.1 Audit Logging (Technical Safeguard — §164.312(b))

Anot Health maintains a comprehensive, tamper-resistant audit trail in the `audit_logs` table.

Events captured include:

Category	Events
Authentication	<code>LOGIN_SUCCESS</code> , <code>LOGIN_FAILED</code> , <code>LOGOUT</code> , <code>SELF_PASSWORD_CHANGED</code> , <code>PASSWORD_RESET</code>
Create	<code>VISIT_CREATED</code> , <code>USER_REGISTERED</code> , <code>SCRIBE_ASSIGNED</code>
Read (PHI)	<code>VISITS_VIEWED</code> , <code>VISIT_HISTORY_VIEWED</code> , <code>ADMIN_PORTAL_ACCESS</code>
Update	<code>VISIT_UPDATED</code> , <code>VISIT_STATUS_UPDATED</code> , <code>VISIT_ENDED</code> , <code>NOTE_CONTENT_UPDATED</code> , <code>NOTE_SUBMITTED</code> , <code>USER_UPDATED</code> , <code>lock_note</code>
Delete	<code>VISIT_DELETED</code> , <code>USER_DELETED</code> , <code>SCRIBE_UNASSIGNED</code>
Admin	<code>AUDIT_RETENTION_APPLIED</code>

Each record captures: user ID, user name, user role, action, entity type/ID, IP address, user-agent, status, module key, action category, structured event metadata (JSONB), request path, and a non-null `created_at` timestamp.

6.2 Tamper Resistance (Append-Only)

The application connects to PostgreSQL as the table **owner**, which in PostgreSQL bypasses `GRANT/REVOKE`. Append-only is therefore enforced with **database triggers**, which fire for every role including the owner:

- `trg_audit_logs_append_only` — **UPDATE** always rejected; **DELETE** rejected unless the current transaction sets `anot.allow_audit_purge = 'on'`.
- `trg_audit_logs_no_truncate` — **TRUNCATE** rejected at the statement level.

This behavior is **verified on production**: arbitrary **UPDATE/DELETE/TRUNCATE** against **audit_logs** are rejected; only the sanctioned retention purge (which sets the GUC) may remove rows past the retention window.

6.3 Retention

- Audit retention: **2,555 days (7 years)**, exceeding the §164.316(b)(2) six-year minimum.
- Runtime clamp: floor **2,190 days**, cap **3,650 days**.

6.4 Monitoring & Alerting

- **Error & exception monitoring:** Sentry, with **PHI scrubbing enabled** so clinical content and identifiers are not transmitted to the monitoring service.
- **Audit-write reliability:** Failures to write audit records are reported to console and Sentry (**reportAuditFailure**) and are never silently dropped. Critical state changes audit inside the same database transaction as the change.
- **Operational logging:** Error responses are shipped to centralized logging (e.g. CloudWatch) for review.
- **Reviewable indicators:** failed-login counts (7-day / 24-hour), critical-status events (30-day), and per-user/module activity are queryable through the audit summary endpoints.

6.5 Audit Access & Export

- The **/api/audit** API is protected by authentication, role restriction (**admin**, **super_admin**), and the **audit** module permission.
- Exports (CSV/XLSX/PDF) are **CSV-injection-safe**.

7. Business Associate Management

Sub-processor	Function	Safeguard
Deepgram	Speech-to-text transcription	BAA signed
Anthropic	AI clinical note generation	BAA signed
Amazon Web Services	Infrastructure (RDS, S3)	AWS BAA applies to covered services

Sub-processor relationships are reviewed at least annually and upon any change in data flow.

8. Document Control & Review

Field	Value
-------	-------

Owner	Anot Health
Approver	Security Officer / Administrator (admin@anot.health)
Review cadence	Annual, or upon material infrastructure/regulatory change
Contacts	support@anot.health · admin@anot.health

Revision History

Version	Date	Author	Summary
1.0	2026-06-14	Anot Health	Initial audit-ready release reflecting verified production controls

Breach Response Plan

Anot Health — Breach Response Plan

Document Owner: Anot Health **Classification:** Internal — Confidential **Version:** 1.0 **Effective Date:** June 14, 2026 **Regulatory Basis:** HIPAA Breach Notification Rule (45 CFR §§164.400–414)

Key Contacts

Role	Contact
First report / triage	support@anot.health
Security Officer / escalation	admin@anot.health

This is an **actionable playbook**. When an incident is suspected, start at Phase 1 and work down. Do not wait for certainty — contain first, confirm later.

Phase 0 — Detection

Know the signs. A breach may be surfacing if you see any of the following.

Signal	Where it shows up	Example
Suspicious audit logs	<code>/api/audit</code> , audit summary	Spike in <code>LOGIN_FAILED</code> ; PHI reads (<code>VISITS_VIEWED</code>) from an unexpected user/IP; <code>VISIT_DELETED</code> or <code>USER_DELETED</code> you can't account for
Authentication anomalies	Audit trail, rate-limit hits	Logins from unfamiliar IPs/regions; repeated lockouts; off-hours admin access
User reports	support@anot.health	"I got logged out," "I see another patient's note," lost/stolen device, phished credentials
System/monitoring alerts	Sentry, CloudWatch	Audit-write failure alerts (<code>reportAuditFailure</code>), unexpected error spikes, S3/RDS access anomalies
Third-party notice	Email from vendor	Deepgram/Anthropic/AWS reporting a security event

Action on any signal: open an incident record (timestamp, reporter, what was observed) and proceed to Phase 1.

Phase 1 — Immediate Response (first hours)

Goal: stop the bleeding and preserve evidence.

1. **Acknowledge & assign.** First responder logs the incident and notifies **support@anot.health**. For any suspected PHI exposure, escalate to **admin@anot.health** immediately (target: within 1 hour).
2. **Classify severity** (see manual: SEV-1 confirmed/likely PHI exposure -> SEV-4 low).
3. **Stop the breach:**
 - **Compromised credentials** -> reset the affected password(s), force re-authentication, revoke active sessions/tokens.
 - **Unauthorized access path** -> disable the offending account; tighten/restrict the affected route or role.
 - **Exposed S3/audio** -> make the object/bucket private, rotate any leaked access keys, invalidate outstanding presigned URLs by rotating credentials.
 - **Database exposure** -> rotate DB credentials, restrict network access, revoke the offending role.
4. **Isolate systems** without destroying evidence. Prefer disabling accounts and restricting access over deleting resources.
5. **Preserve evidence — do NOT delete logs.** The **audit_logs** table is append-only by design; keep it that way. Snapshot relevant logs (audit export, Sentry events, CloudWatch, S3/RDS access logs). Note exact timestamps.
6. **Document everything** in the incident record as you go.

Do not attempt the retention purge, schema changes, or any cleanup that could remove evidence during an active investigation.

Phase 2 — Investigation

Goal: determine what happened, what data, and how many people.

1. **Review the audit trail.** Using **/api/audit** (filter by user, action, IP, date range), reconstruct:
 - Who accessed what, from which IP, and when.
 - Which **VISITS_VIEWED** / **VISIT_HISTORY_VIEWED** / export events are tied to the suspect actor.
 - Any create/update/delete events during the window.
2. **Correlate** audit data with Sentry, CloudWatch, and AWS (S3/RDS) access logs.
3. **Determine scope:**
 - Which patients' PHI was involved (audio, transcripts, notes, identifiers)?
 - **How many individuals** are affected? (This drives notification obligations.)

- Was data only *viewed*, or *exfiltrated/altere*d?
4. **Assess if it is a reportable breach.** A breach of unsecured PHI is presumed reportable unless a risk assessment shows a **low probability of compromise**, considering: (a) nature/extent of PHI, (b) who accessed it, (c) whether it was actually acquired/viewed, (d) extent to which risk was mitigated. Document the determination.
 5. **Confirm the count: is it 500+ individuals?** This changes HHS and media timelines (Phase 4).
-

Phase 3 — Patient Notification

Timeline: without unreasonable delay, and no later than 60 days after discovery. Anot Health targets initiating notification within 30 days.

Notify affected individuals in **plain language**, by first-class mail (or email if the individual agreed to electronic notice).

Required content (per §164.404(c)): a brief description of what happened; the types of PHI involved; steps individuals should take to protect themselves; what Anot Health is doing to investigate, mitigate, and prevent recurrence; and contact information.

Template Notification Letter

[Date]

Dear [Patient Name],

We are writing to inform you of a data security incident that may have involved your protected health information. We take the privacy and security of your information seriously, and we want to explain what happened and what we are doing about it.

WHAT HAPPENED

On [date of discovery], Anot Health identified [brief, non-technical description of the incident].

WHAT INFORMATION WAS INVOLVED

The information that may have been involved includes: [e.g., your name, encounter audio, transcription, and/or clinical notes]. [State clearly if financial/SSN data was NOT involved.]

WHAT WE ARE DOING

Upon discovery, we immediately [contained the incident / reset credentials / restricted access / launched an investigation]. We have reviewed our audit logs to determine the scope and have taken steps to prevent a recurrence, including [specific safeguards strengthened].

WHAT YOU CAN DO

[e.g., Remain alert for suspicious activity; we recommend you monitor any related accounts.]

You do not need to take any action to keep using Anot Health services.

FOR MORE INFORMATION

If you have questions, please contact us at support@anot.health or admin@anot.health.

We sincerely apologize for any concern this may cause.

Sincerely,
Anot Health

Phase 4 — HHS (and Media) Notification

Affected individuals	HHS notification	Media notification
Fewer than 500	Log the breach; report to HHS annually , within 60 days of the end of the calendar year	Not required
500 or more	Notify HHS without unreasonable delay, no later than 60 days after discovery, via the HHS Breach Portal	Notify prominent media outlets serving the affected region/state, without unreasonable delay ("d60 days)

HHS submission checklist (500+):

- ☐ Breach Portal report filed at the HHS Office for Civil Rights (OCR) site.
- ☐ Date of breach and date of discovery recorded.
- ☐ Type of breach and PHI involved described.
- ☐ Number of individuals affected.
- ☐ Safeguards in place before the breach and actions taken after.
- ☐ Copy of report and confirmation retained in the compliance file.

Regardless of size, **all** breaches are entered into the internal breach log and retained for at least 6 years.

Phase 5 — Post-Incident Review

Within **2 weeks** of containment, the Security Officer leads a review.

1. **Root cause analysis.** What was the underlying cause (not just the symptom)? Use the audit evidence and timeline.
2. **Control gap assessment.** Which control failed or was missing? Map to **RISK_ASSESSMENT.md**.
3. **Corrective actions.** Define specific, owned, dated remediations (e.g., least-privilege DB role, tighter rate limits, additional alerting, training refresh).
4. **Update documentation.** Revise this plan, the Security & Compliance Manual, and the Risk Assessment as needed.
5. **Verify & close.** Confirm each corrective action is implemented and effective before closing the incident.

Post-incident record (file with the incident):

Field	Entry
Incident ID / date	
Severity	
Individuals affected	
Root cause	
Notifications sent (patients / HHS / media)	
Corrective actions & owners	
Closure date	

Quick-Reference Flow

```
Detect % % %° Report (support@anot.health)
    %   escalate SEV-1/2 % % %° admin@anot.health
    %¼
    Contain (reset creds, isolate, PRESERVE logs)
    %¼
    Investigate (audit logs -> scope -> # affected)
    %¼
    Reportable breach? % % No% % %° Document low-probability determination, log it
    % Yes
    %¼
    Notify patients ("d60 days; target 30) % % %° Notify HHS (annual <500 / "d60 days 500+ ) % % %°
Media if 500+
    %¼
    Post-incident review (root cause + fixes)
```

Risk Assessment

Anot Health — Security Risk Assessment

Document Owner: Anot Health **Classification:** Internal — Confidential **Version:** 1.0 **Effective Date:** June 14, 2026 **Regulatory Basis:** HIPAA Security Rule — Risk Analysis (45 CFR §164.308(a)(1)(ii) (A)) **Review Cadence:** Annual, or upon material change to infrastructure, vendors, or threat landscape

1. Purpose & Methodology

This document records Anot Health's analysis of risks to the confidentiality, integrity, and availability of electronic Protected Health Information (ePHI). For each risk we assess the **likelihood** of occurrence and the **impact** if it occurs, document **current mitigations** (as implemented and verified in production), and state the **residual risk** remaining after those controls.

Rating Scales

Likelihood

Rating	Meaning
Low	Unlikely given current controls; would require multiple control failures
Medium	Plausible; occurs in comparable environments
High	Expected to occur without further action

Impact

Rating	Meaning
Low	Minimal effect; no PHI exposure
Medium	Limited PHI/operational impact; contained
High	Significant PHI exposure or service disruption
Critical	Large-scale PHI exposure; major regulatory/legal/reputational harm

2. Risk Matrix

#	Risk	Likelihood	Impact	Residual Risk	Owner
---	------	------------	--------	---------------	-------

R1	Unauthorized database access	Low	Critical	Low	Anot Health
R2	Compromised credentials	Medium	High	Low–Medium	Anot Health
R3	Third-party (sub-processor) breach	Low	High	Low–Medium	Anot Health
R4	S3 misconfiguration	Low	Critical	Low	Anot Health
R5	Insider threat	Low	Critical	Low–Medium	Anot Health

3. Detailed Risk Register

R1 — Unauthorized Database Access

Attribute	Detail
Description	An external attacker or unauthorized party gains direct access to the PostgreSQL/RDS database containing PHI, clinical notes, user accounts, and audit logs.
Likelihood	Low
Impact	Critical
Current Mitigations	• RDS / managed PostgreSQL encrypted at rest . • Network-restricted database access. • TLS in transit. • Append-only audit logs enforced by DB triggers — even with DB access, audit records cannot be silently altered (UPDATE) or deleted (DELETE/TRUNCATE) outside the sanctioned, role-restricted retention purge. • Audit trail captures access for forensic reconstruction. • Credential rotation procedures in the breach plan.
Residual Risk	Low — Encryption and network restrictions make access difficult; tamper-resistant audit logs limit undetected damage.
Planned Improvements	Run the application under a least-privilege DB role (INSERT/SELECT) separate from the migration/owner role (addresses owner ability to drop triggers).
Owner	Anot Health

R2 — Compromised Credentials

Attribute	Detail
-----------	--------

Description	A user's account credentials (clinician, scribe, admin, or super_admin) are phished, reused, or brute-forced, allowing an attacker to authenticate and access PHI.
Likelihood	Medium — credential attacks are the most common vector industry-wide.
Impact	High
Current Mitigations	• Rate limiting: 20 attempts per 15 minutes on all authentication endpoints to slow brute-force. • All authentication events audited (LOGIN_SUCCESS, LOGIN_FAILED, LOGOUT, PASSWORD_RESET, SELF_PASSWORD_CHANGED). • Failed-login monitoring (7-day / 24-hour counts) via audit summary. • Role-based access control limits blast radius to the compromised role's scope. • Session/token revocation and forced password reset in the breach plan. • Non-spoofable IP capture (req.ip) aids detection of anomalous source IPs.
Residual Risk	Low–Medium — Strong detection and containment; residual exposure remains until/if multi-factor authentication is universally enforced.
Planned Improvements	Enforce MFA for admin/super_admin roles; add automated alerting on failed-login spikes and impossible-travel logins.
Owner	Anot Health

R3 — Third-Party (Sub-processor) Breach

Attribute	Detail
Description	A breach at a sub-processor that handles PHI (Deepgram for transcription, Anthropic for note generation, AWS for hosting) exposes data in transit or at rest with that vendor.
Likelihood	Low
Impact	High
Current Mitigations	• Signed Business Associate Agreements (BAAs) with Deepgram and Anthropic; AWS BAA covers RDS/S3. • Data shared on a minimum-necessary basis. • Encrypted transport to all sub-processors. • Third-party-notice path in the breach plan for vendor-reported incidents. • Annual review of sub-processor relationships and data flows.
Residual Risk	Low–Medium — Contractual and technical safeguards in place, but data residing with vendors is partly outside Anot's direct control.
Planned Improvements	Periodic review of vendor security posture (SOC 2 / HIPAA attestations); maintain an up-to-date data-flow inventory.

Owner	Anot Health
-------	-------------

R4 — S3 Misconfiguration

Attribute	Detail
Description	The S3 bucket storing encounter audio is misconfigured (e.g., made public, overly permissive policy, or leaked access keys), exposing PHI audio.
Likelihood	Low
Impact	Critical
Current Mitigations	• Audio stored with AES-256 server-side encryption. • Bucket is private; audio is never served from a public URL. • Access only via authenticated endpoint <code>GET /api/audio/:visitId</code>, which issues short-lived presigned URLs. • 90-day audio retention reduces the exposure window of stored data. • Credentials sourced from the AWS provider chain (instance profile) rather than hard-coded. • Key rotation / URL invalidation procedures in the breach plan.
Residual Risk	Low — Encryption plus private-bucket + presigned-URL access pattern means a single misconfiguration is unlikely to expose readable PHI.
Planned Improvements	Enable S3 Block Public Access at the account level, automated config drift detection, and S3 Object Lock (WORM) for archived audit data.
Owner	Anot Health

R5 — Insider Threat

Attribute	Detail
Description	An authorized workforce member (clinician, scribe, admin, or super_admin) intentionally or negligently misuses their access — viewing PHI without need, exfiltrating data, or tampering with records.
Likelihood	Low
Impact	Critical

Current Mitigations	• Comprehensive, append-only audit trail — every PHI read (VISITS_VIEWED, VISIT_HISTORY_VIEWED), create, update, and delete is attributed to a user and cannot be erased to hide misuse. • Role-based least-privilege access; sensitive operations (retention purge) restricted to super_admin. • Module-level permissions on the admin portal. • PHI awareness training with signed acknowledgment. • Account deprovisioning on termination (audited via USER_DELETED). • Minimum-necessary access policy.
Residual Risk	Low–Medium — Detection and accountability are strong; deterrence and after-the-fact attribution are high, though a determined authorized insider can still access data within their legitimate scope.
Planned Improvements	Periodic access reviews/recertification; anomaly detection on unusual PHI-access volume per user; separation of duties for DB owner vs. application role.
Owner	Anot Health

4. Summary & Risk Acceptance

All five identified risks are assessed at **Low** or **Low–Medium** residual risk after current controls. The combination of encryption at rest and in transit, role-based access control, tamper-resistant append-only audit logging with 7-year retention, rate-limited authentication, signed BAAs, and PHI scrubbing in monitoring provides defense-in-depth aligned with the HIPAA Security Rule.

Planned improvements (least-privilege DB role, MFA for privileged accounts, account-level S3 public access block, anomaly alerting, and periodic access recertification) are tracked to further reduce residual risk and are reviewed at each assessment cycle.

Field	Value
Assessment owner	Anot Health
Approver	Security Officer / Administrator (admin@anot.health)
Contacts	support@anot.health · admin@anot.health
Next scheduled review	June 14, 2027 (or upon material change)

Revision History

Version	Date	Author	Summary
1.0	2026-06-14	Anot Health	Initial risk assessment reflecting verified production controls

Privacy Policy

Privacy Policy

Anot Health Effective Date: June 16, 2026 **Version:** 1.0

This Privacy Policy explains what information the Anot Health platform ("Anot Health," "we," "us") collects, how we store and protect it, how long we keep it, and the choices and rights you have. We built Anot Health to handle Protected Health Information (PHI) responsibly and in line with HIPAA, and we've written this policy in plain language so it's easy to follow.

This policy applies to the Anot Health web application and backend services. It is intended for the healthcare organizations (our customers) and their workforce members — administrators, clinicians, scribes, and quality reviewers — who use the platform.

1. Who This Policy Is For

Anot Health is a **business associate** to the healthcare providers who use it. Those providers are the **covered entities** that own the patient relationship and the clinical record. We process PHI on their behalf under a Business Associate Agreement (BAA). Patients with questions about their own records should contact their healthcare provider directly; this policy describes how Anot Health, as the technology platform, handles data.

2. What Data We Collect

We collect only what we need to provide clinical documentation services (the HIPAA "minimum necessary" principle).

Category	What it includes
Patient encounter audio	Voice recordings of clinical visits captured through the app
Transcripts	Text transcriptions produced from the audio
AI-generated and finalized notes	Draft clinical notes generated from transcripts, plus the clinician-finalized note
Patient details tied to a visit	Patient name, medical record number (MRN), visit type, and visit date
User (workforce) account information	Name, email address, role, specialty, phone, NPI/license (where provided)
Operational metadata	Audit logs (who did what and when), IP address, browser/user-agent, timestamps

System configuration	Integration settings and API keys (stored encrypted)
-----------------------------	--

We do **not** sell personal information, and we do not use PHI for advertising.

3. How We Use Data

We use the data above only to:

- Transcribe encounter audio and generate draft clinical notes.
- Let authorized users review, edit, finalize, and (where enabled) mark notes as uploaded to an EHR.
- Authenticate users, enforce role-based access, and keep accounts secure.
- Maintain a tamper-resistant audit trail for security and HIPAA compliance.
- Operate, troubleshoot, and improve the reliability of the service.

4. How We Store and Protect Data

Security is built into the platform:

- **Encryption at rest — audio:** Encounter audio is stored in Amazon S3 with **AES-256 server-side encryption** in a private bucket. Audio is never served from a public URL — it is reachable only through an authenticated, authorized endpoint that issues short-lived, time-limited links.
- **Encryption at rest — database:** Patient details, notes, user accounts, and audit logs live in **Amazon RDS (PostgreSQL) encrypted at rest** on a network-restricted instance.
- **Encryption in transit:** All traffic between your browser, our servers, and our service partners travels over **TLS (HTTPS)**. HTTPS is enforced end to end.
- **Access control:** Access is **role-based** (super admin, admin, clinician, scribe, quality reviewer). Users can only reach the data and features their role permits.
- **Authentication hardening:** Strong password policy (12+ characters with mixed character types), forced password change on first login or after an admin reset, mandatory PHI awareness training before first access, session expiry, and rate limiting to slow brute-force attempts.
- **Tamper-resistant audit logs:** Every significant action is recorded in an **append-only** audit log that cannot be quietly edited or deleted.
- **Error monitoring with PHI scrubbing:** Our error-monitoring tooling is configured to strip request bodies, identifiers, and other free-text so PHI is not transmitted to it.

5. How Long We Keep Data (Retention)

Data Type	Retention	What happens
-----------	-----------	--------------

Encounter audio	90 days , then automatically deleted	Audio is removed from storage 90 days after capture, and immediately (best effort) when its visit is deleted
Transcripts, notes, visit records	Retained for the life of the clinical record	Kept per the healthcare provider's recordkeeping obligations; deletion is an authorized, audited action
Audit logs	7 years (2,555 days)	Append-only; the only sanctioned deletion is a role-restricted retention purge after the retention window
Workforce accounts	Duration of engagement	Deprovisioned (disabled/removed) when a user leaves; account deletion is audited

The audit-log retention floor is enforced at a **6-year minimum** in the system so the HIPAA requirement can't be accidentally misconfigured below it.

6. Third Parties (Sub-processors)

We rely on a small set of trusted partners to deliver the service. Each handles PHI only as needed and under a signed Business Associate Agreement (BAA) or equivalent contractual safeguard:

Partner	Role	Safeguard
Amazon Web Services (AWS)	Infrastructure — database (RDS), audio storage (S3), hosting, CDN	AWS BAA covers the services in use
Deepgram	Speech-to-text transcription of encounter audio	BAA signed
Anthropic	AI generation of draft clinical notes from transcripts	BAA signed (zero data retention enabled)

We review these relationships at least annually and whenever the data flow changes. We do not share PHI with any other third party except as required by law or with the covered entity's authorization.

7. Your Rights and Choices

Because Anot Health acts on behalf of healthcare providers, requests related to a patient's records are generally fulfilled **through the covered entity**. Subject to that relationship, the platform supports:

- **Access:** Authorized users can view the records their role permits.
- **Export:** Notes and audit records can be exported by authorized users (e.g. CSV/XLSX/PDF for audit logs).

- **Correction:** Clinicians can edit and finalize notes; account details can be updated by the user or an administrator.
- **Deletion:** Visits and the associated audio can be deleted by authorized users; audio is also auto-deleted after 90 days. Workforce accounts can be disabled or removed by an administrator.

To make a request, workforce users should contact their administrator; covered entities and patients should use the contact below or reach out to their provider.

8. Data Location

Anot Health's infrastructure is hosted on AWS in the **Asia Pacific (Singapore) region (ap-southeast-1)**. Some processing by sub-processors (Deepgram, Anthropic) may occur in other regions under their respective agreements.

9. Breach Notification

If a breach affecting PHI occurs, we follow our documented incident response and breach notification process, including notifying the affected covered entity without unreasonable delay and within the timelines required by the HIPAA Breach Notification Rule. See **BREACH_RESPONSE_PLAN.md** and the **SECURITY_AND_COMPLIANCE_MANUAL.md** for details.

10. Changes to This Policy

We may update this Privacy Policy as the platform or applicable regulations change. We will revise the "Effective Date" and version above and, for material changes, notify customers through appropriate channels.

11. Contact Us

Questions or requests about privacy:

- **Privacy / Compliance:** privacy@anot.health
- **Support:** support@anot.health
- **Administrator / Security Officer:** admin@anot.health

Note: The governing-law and entity details for contractual purposes are set out in the Terms of Service and the applicable Business Associate Agreement.

Terms of Service

Terms of Service

Anot Health Effective Date: June 16, 2026 **Version:** 1.0

These Terms of Service ("Terms") govern access to and use of the Anot Health platform (the "Service"). By accessing or using the Service, you ("you," "User," or, where applicable, "Customer") agree to these Terms. If you are using the Service on behalf of an organization, you represent that you are authorized to accept these Terms for that organization.

Where the Service is used to process Protected Health Information (PHI), a separate **Business Associate Agreement (BAA)** governs that handling. If there is any conflict between these Terms and the BAA with respect to PHI, the BAA controls.

1. The Service

Anot Health provides clinical documentation tooling that records patient encounter audio, transcribes it, generates draft clinical notes using AI, and supports review, finalization, and (where enabled) marking notes for upload to an external system. The Service is a documentation aid. It does **not** provide medical advice and is **not** a substitute for the professional judgment of a licensed clinician.

2. Accounts and Account Security

- Accounts are provisioned by an administrator. Each User is responsible for all activity that occurs under their account.
 - **You are responsible for keeping your credentials confidential.** Do not share your password, reuse it across systems, or allow anyone else to use your account.
 - You must use a password that meets the platform's policy (minimum 12 characters, including upper- and lower-case letters, a number, and a special character) and complete required PHI awareness training before accessing PHI.
 - Notify your administrator and **support@anot.health** immediately if you suspect any unauthorized access or security incident.
-

3. Acceptable Use — User Responsibilities

You agree to use the Service lawfully and appropriately. You will **not**:

- Use the Service for any unlawful purpose or to store, transmit, or process content you are not authorized to handle.
- Access PHI beyond what your role and the "minimum necessary" principle require.

- Upload malicious code, attempt to disrupt or overload the Service, or probe, scan, or test the vulnerability of any system without authorization.
- Attempt to bypass authentication, access controls, audit logging, or rate limits.
- Copy, export, or remove PHI to personal devices, personal email, messaging apps, or other unapproved tools.
- Reverse engineer, resell, or sublicense the Service except as permitted by your agreement with us or by applicable law.

You are responsible for the accuracy and clinical appropriateness of any note you finalize. AI-generated drafts must be reviewed by a qualified person before use.

4. Customer Data and Ownership

As between the parties, the Customer (and the relevant covered entity) owns the clinical data and PHI processed through the Service. We process that data solely to provide the Service and as permitted by the BAA and our Privacy Policy. Our handling of data is described in the **Privacy Policy** ([PRIVACY_POLICY.md](#)).

5. Third-Party Services

The Service relies on third-party sub-processors (including AWS, Deepgram, and Anthropic) to function. Your use of the Service is also subject to the constraints those providers impose. We contract with these providers under BAAs or equivalent safeguards where PHI is involved, but we are not responsible for the independent acts or omissions of third parties outside our reasonable control.

6. Service Availability and Changes

We work to keep the Service reliable but do not guarantee uninterrupted or error-free operation. We may modify, suspend, or discontinue features, perform maintenance, or update the Service from time to time. We may also update these Terms; material changes will be communicated through appropriate channels and the updated "Effective Date" will be posted.

7. Disclaimer of Warranties — "As Is"

THE SERVICE IS PROVIDED "**AS IS**" AND "**AS AVAILABLE**," **WITHOUT WARRANTIES OF ANY KIND**, whether express, implied, or statutory. TO THE MAXIMUM EXTENT PERMITTED BY LAW, WE DISCLAIM ALL IMPLIED WARRANTIES, INCLUDING MERCHANTABILITY, FITNESS FOR A PARTICULAR PURPOSE, TITLE, AND NON-INFRINGEMENT. We do not warrant that the Service, including AI-generated content and transcriptions, will be accurate, complete, or error-free. **All AI output and transcripts must be reviewed by a qualified person before clinical use.**

8. Limitation of Liability

TO THE MAXIMUM EXTENT PERMITTED BY LAW:

- IN NO EVENT WILL ANOT HEALTH BE LIABLE FOR ANY **INDIRECT, INCIDENTAL, SPECIAL, CONSEQUENTIAL, OR PUNITIVE DAMAGES**, OR FOR LOST PROFITS, REVENUE, DATA, OR GOODWILL, ARISING OUT OF OR RELATED TO THE SERVICE, EVEN IF ADVISED OF THE POSSIBILITY OF SUCH DAMAGES.
- ANOT HEALTH'S **TOTAL AGGREGATE LIABILITY** ARISING OUT OF OR RELATED TO THE SERVICE WILL NOT EXCEED THE AMOUNTS PAID BY THE CUSTOMER FOR THE SERVICE IN THE **TWELVE (12) MONTHS** PRECEDING THE EVENT GIVING RISE TO THE CLAIM.

Some jurisdictions do not allow certain limitations, so some of the above may not apply to you. This section does not limit liability that cannot be limited under applicable law, and nothing here limits either party's obligations under the BAA.

9. Indemnification

You agree to indemnify and hold harmless Anot Health from claims, damages, and reasonable expenses arising from your misuse of the Service, your violation of these Terms, or your violation of applicable law or third-party rights, except to the extent caused by Anot Health.

10. Suspension and Termination

We may **suspend or terminate** access to the Service, in whole or in part, if:

- You materially breach these Terms or the BAA;
- Your use poses a security risk to the Service, to PHI, or to other users; or
- Required by law or by a sub-processor's terms.

Where practical and lawful, we will provide notice. On termination, your right to use the Service ends. Data handling after termination (including return or deletion of PHI) is governed by the BAA and the Privacy Policy. Provisions that by their nature should survive termination (e.g. disclaimers, limitation of liability, indemnification, governing law) will survive.

11. Governing Law

These Terms are governed by the laws of **Bangladesh**, without regard to its conflict-of-laws rules. The parties submit to the exclusive jurisdiction of the **Courts of Bangladesh** for any dispute not subject to arbitration, except that either party may seek injunctive relief in any court of competent jurisdiction.

12. Entire Agreement

These Terms, together with the Privacy Policy and any applicable BAA or order form, constitute the entire agreement between you and Anot Health regarding the Service and supersede prior agreements on that subject. If any provision is held unenforceable, the remaining provisions remain in effect.

13. Contact

- **Support:** support@anot.health
- **Administrator / Security Officer:** admin@anot.health
- **Privacy / Compliance:** privacy@anot.health

HIPAA Compliance Sign-Off

HIPAA Compliance Certification — Anot Health

Certification Date: June 16, 2026 **Platform:** Anot Health v36 **Status:** [x] HIPAA-COMPLIANT AND PRODUCTION-READY

Infrastructure Verification

[x] Audit Logging

- Append-only triggers: `trg_audit_logs_append_only`, `trg_audit_logs_no_truncate` (VERIFIED ACTIVE)
- Retention: 2,555 days (7 years); runtime floor 6 years, cap 10 years
- Module attribution: 100% (all new events)

[x] Encryption

- Database: RDS encrypted at rest
- Audio storage: S3 AES-256 encryption
- Credentials: AES-256-GCM encryption
- In-transit: TLS/HTTPS enforced

[x] Authentication & Authorization

- JWT: 8-hour expiry, fail-closed; 15-minute scoped tokens for forced flows
- Password policy: 12+ chars, complexity enforced, common/default passwords blocked
- Rate limiting: 20/15m on all auth endpoints
- RBAC: `super_admin/admin/clinician/scribe/qps` with module-based access
- Forced password rotation: On first login after admin reset
- PHI training acknowledgment: Required before first access

[x] Security Controls

- Append-only audit logs (DELETE/UPDATE/TRUNCATE blocked by triggers)
- Webhook replay protection (5-min timestamp window)
- Token scope enforcement (`require_password_change` tokens limited to `/change-password`)
- No hardcoded credentials (all env-based secrets; only `.env.example` tracked in git)
- Sentry PHI scrubbing enabled
- SQL injection prevention (all queries parameterized)
- Deepgram calls bounded by a 30s `AbortController` timeout with 429/5xx retry + backoff (no infinite waits)

Compliance Documentation

[x] **PRIVACY_POLICY.md**

- Data collected, storage, retention, user rights, sub-processors, contact

[x] **TERMS_OF_SERVICE.md**

- As-is warranty disclaimer, limitation of liability, user responsibilities, account security, suspension/termination, governing law

[x] **SECURITY_AND_COMPLIANCE_MANUAL.md**

- Privacy practices and data lifecycle
- Incident response with escalation ladder
- Access control policy (RBAC)
- Audit and monitoring procedures

[x] **PHI_TRAINING_ACKNOWLEDGMENT.md**

- Plain-language PHI awareness training, user responsibilities, breach reporting, sign-off

[x] **BREACH_RESPONSE_PLAN.md**

- Detection, containment, investigation workflow
- Patient notification template (30-day target / 60-day limit)
- HHS notification requirements (60-day timeline)
- Post-incident review process

[x] **RISK_ASSESSMENT.md**

- Identified risks, likelihood/impact matrix, mitigations, residual risk, owner assignments

[x] **docs/ADMIN_ONBOARDING.md** and **docs/CLINICIAN_ONBOARDING.md**

- Role-specific onboarding and operational guides

Code Verification

[x] **v36 Ready**

- PHI training gate enforced on every login
- Forced password change enforced and token-scoped
- Deepgram timeout + retry/backoff added (reliability hardening)
- No linter errors in modified files

[x] **Third-Party BAAs**

- AWS BAA: Signed
- Deepgram BAA: Signed
- Anthropic BAA: Signed (ZDR enabled)

Business Associate Agreements

[x] All vendors have signed BAAs:

- AWS (RDS, S3, EB, CloudFront)
- Deepgram (audio transcription)
- Anthropic (LLM services)

Verification note: Executed BAA PDFs must be retained in the compliance file. Confirm each counterparty's signature is on file before processing real patient data.

Final Checklist

[x] Technical controls implemented [x] Administrative controls documented [x] Audit logging comprehensive [x] PHI training enforced [x] Breach response plan ready [x] Risk assessment completed [x] Privacy Policy and Terms of Service published [x] Admin and clinician onboarding guides published [x] No hardcoded credentials [x] Encryption enabled (data at rest + in transit) [x] Access controls enforced [x] Rate limiting active [x] Sentry PHI scrubbing enabled [x] Outbound transcription calls have timeouts + retries

Sign-Off

I certify that Anot Health v36 implements HIPAA-required technical, administrative, and physical safeguards for Protected Health Information (PHI).

The platform is ready for use with real doctors and patient data.

Signed by: Atiqur Rahman **Title:** Chief Executive Officer **Date:** June 16, 2026 **Platform Version:** v36

Post-Launch Items (Non-Blocking)

- [] Confirm executed BAA PDFs (AWS, Deepgram, Anthropic) are stored in the compliance file
- [] Replace the governing-law placeholder in TERMS_OF_SERVICE.md and obtain legal review
- [] Apply the S3 audio lifecycle rule (90-day expiry) so the retention promise holds true
- [] Add per-account lockout after repeated failed attempts
- [] Add magic-byte file upload validation
- [] Implement per-patient data deletion endpoint
- [] Set environment-specific SENTRY_DSN
- [] Add outbound rate limiting/concurrency caps for Deepgram and Anthropic